An agile framework for quantitative risk assessment in a Security Operations Centre (SOC)

Russell Ballantine

Master of Science

Informatics

School of Informatics

University of Edinburgh

2022

Abstract

The network security industry is missing a quantifiable strategy for collating security information, assessing risk and making evidence based decisions. Significant corporate spending occurs on network infrastructure and security tools without a quantitative evaluation of the risk reduction resulting from the effectiveness of chosen security strategies. The framework created in this work improves on singular data abstraction approaches to security by using an ontological, metric driven description of security controls coupled with a graphical view of the threat landscape to provide a probabilistic determination of risk. The threat landscape is described using a traditional attack graph, built from a vulnerability scan, converted to a Bayesian Network which is updated by adding new information to the security ontology. A Game Theory approach is then used to inform control selection based on risk outcomes from the Bayesian Network. The framework is demonstrated and evaluated by building a working risk and decision making model, using open source tools and a small test network. Statistical methods are used to investigate the sensitivity of the models outputs and the decision outcomes are compared with qualitative judgments from security professionals on appropriate control selection to secure the test network. Summary statistics and sensitivity ranges are provided only for the game winning decision outcome node but information for all nodes is inherent and viewable in the Bayesian Network. The framework may provide a useful adjunct to the decision making process on security tool deployment and control selection within SOC environments. Describing the security environment within an ontology is a time-consuming but one-time exercise. Once complete, further security environment changes are easily and quickly captured.

Acknowledgements

I would like to thank David Aspinall, for his advice and assistance. His suggestions always provided inspiration and were invaluable in allowing me to complete this project. I would also like to thank my wife and family for their love and support throughout this endeavour.

Table of Contents

1 Introduction **1**

1.1 Motivation 1

1.2 Threat Modelling 3

1.3 Structure 4

2 Background **5**

2.1 The Common Vulnerability Scoring System (CVSS) 5

2.2 Attack Graph Representation Using MulVAL 6

2.2.1 Adding Probabilities to the Attack Graph 8

2.3 Extending the Attack Graph to a Bayesian Network 9

2.3.1 Interpreting the Bayesian Network 10

2.4 Using OWL to provide a security knowledge base 11

2.4.1 Cyber Essentials as an Ontology 12

2.5 Making decisions using Game Theory 13

3 Designing and Implementing the Framework **15**

3.1 Using MulVAL and Input Data Sources 16

3.1.1 Creation of the input.P file 16

3.2 Creating and using a Security Ontology 18

3.2.1 Countermeasure strategies for security 19

3.3 Forming and Updating the Bayesian Network 22

3.4 Cost and Decision making 23

3.4.1 The Decision making strategy 24

3.5 The Framework as an Agile Design Pattern 26

4 Implementation and Evaluation **27**

4.1 Attack Graph Formation 28

4.2 A Simple Cost Function 29

4.3 Evaluating risk reduction for policies 1-8 31
4.4 Using a game for policy selection 35
4.5 Evaluating the Risk and Decision Outcomes 35
4.6 Deterministic Policy Selection(Expert Opinion) 38

5 Conclusions **39**

Bibliography **41**

A MulVAL Input File **45**
A.1 input.P file 45

B OWL and Protege **49**
B.1 Cyber Essential controls as OWL attributes 49
B.2 Security Policies for Evaluation 50

C Tools Summary **54**

D Attack Graph from Chapter4 **55**

Chapter 1

Introduction

1.1 Motivation

A risk professional may state the risk of an accident to be $1x10^{-8}$ per year given the estimated failure rate and assuming a correct model. By this, they mean the accuracy of the model needs to be determined and the estimation of failure rate monitored over time for accuracy. Most people just hear "the risk of an accident is $1x10^{-8}$ per year". In a security context, Hiscox's insurance underwriters have suggested that around one business in the UK is successfully hacked every 19 seconds [18]. The point being that risk is a complex concept and using it to bring effective decision making a difficult undertaking. Most enterprise security teams operate some form of risk based control selection. Usually a red, amber, green (RAG) deterministic risk based approach has been used. This has, until recently, been successful in answering questions and meeting the needs of senior management and the board of directors. However, the dissolution of the corporate perimeter, development of the Internet of Things and the importance of cloud applications in many of the latest business models, foiled with the catastrophic corporate failures possible with modern malware and ransomware attacks, is creating new demands from senior management for the quantifying of operational risk which the traditional deterministic RAG schemes cannot deliver [7]. Return on Investment (ROI) for security expenditure and the quantifying of operational risk are now priority items at board level [4]. Unfortunately, deterministic, qualitative approaches to risk rely on expert opinion which is subject to many inherent biases, produces no scientifically measurable, reproducible outcomes and as such cannot produce this metric requirement. An approach to quantitative risk assessment within the fast paced, agile development environments [5] of modern networked systems is required to enhance

qualitative approaches to risk and introduce evidence based decision making criteria.

The National Institute of Standards and Technology (NIST) developed the Common Vulnerability Scoring System (CVSS) [25] which provides a metric representation (base score) of a vulnerability. NIST (and now First.org) advises that the CVSS base scores should be extended to provide temporal and environmental context before use and provides formula to do this [24]. Despite this advice, many organisations are using the base scores, without adjustment, as statements of truth for their risk systems [24]. This dissertation develops the hypothesis that qualitative risk based approaches to security control selection can be improved by combining probabilistic inference using a Bayesian Network (BN) [23], an agile semantic description of a security context [20] and a vulnerability landscape described by attack graph modelling [32].

The concept of agile is important here [5]. Modern network security operational environments, including the Security Operation Centre (SOC), have undergone a revolution in the last 5 years or so. Cloud agility has seen traditional security architecture planning strategies dropped in favour of agile development approaches [6]. In some cases entire network and security architecture departments have faced redundancy with the architecture role being absorbed into the business as usual operational activities of network and security teams. In a misinterpretation of what the agile development paradigm means, some corporate business models now leverage DevOps strategies, without full agile pattern development [27], over traditional waterfall methods. This provides a cost cutting exercise only, removing robust design authority without any effective replacement [6]. This approach to agility has created extensive problems for SOC and other operational teams tasked with picking up the added burden of network and security planning without a corresponding increase in headcount or operational timescales. A framework for risk estimation and control selection is needed that can meet both the agility requirements for development and the risk estimation ask from senior managers on a drastically reduced temporal scale.

The framework developed in this report, creates agility through the use of a small semantic description of the security environment that is scaled only to bring context to the vulnerability scoring. This is then combined with probabilistic measurement of risk via the Bayesian Network leading to a measured assurance level for the strategic approach to control selection performed by game outputs. Outputs produced by the

framework are therefore based on parameter characterisation of uncertainty and variability identified by the threat modelling (rendered by the Bayesian Network) and the impact on the control selection process (calculated by framework APIs) . The outputs produced are:

- An agile pattern in UML [27] describing the security risk framework.
- A small, working environment to illustrate the principles.
- A characterisation of variability across marginal probabilities generated by the Bayesian Network and a confidence level for policy selection.
- A qualitative peer review of security policy selection choices, against a test architecture, used for comparison with the quantitative framework outputs.

An agile framework for quantitative risk analysis should prove useful to security professionals looking to make evidence based assessments of security posture. Providing quantifiable cost benefits for security choices will allow managers to extend the operational risk at the technical infrastructure level to board level political decision making.

1.2 Threat Modelling

In network SOCs, potential threats are analyzed using a threat modelling process [35] of which attack graphs or attack trees are a common example [21]. Attack graphs normally contain no probabilistic information and give no measure of likelihood but do present an inherent causal structure. Threat modelling of modern enterprises faces a number of new challenges, some of which are:

- The ever increasing number of security vulnerabilities and the increasingly distributed Internet of Things make it difficult to prioritise applications in any security approach.
- Attack complexity is increasing. Multi-stage attacks over longer timescales make protection of critical systems with current security approaches challenging.
- New attack vectors and new attacks are appearing with increasing frequency [29].

This dissertation presents an approach to the measurement of network security through the creation of objective metrics used to compare different security approaches. The CVSS base scores are used as a statement of truth for the risk model through extension to an environmental score by the inclusion of an OWL [1] ontological description of security context. Most work on security ontologies in the current literature are large scale and attempt to define the full security footprint of an organisation [10, 14]. In contrast, the approach taken in this work is to produce a security ontology which describes security policy in terms of the network architecture, Cyber Essentials Standard controls [8] and their relationship to the mitigation of network vulnerabilities identified through vulnerability scanning. Agility is enhanced by capturing the framework design characteristics in a UML design pattern and by using the ontology to focus only on the context of the operational risk questions asked by the SOC when setting up a use case for analysis. Cumulative risk metrics are produced using an attack graph which represents both the number of vulnerabilities present and the interaction between those vulnerabilities. Developing attack graphs to a probabilistic interpretation has been the subject of many papers [23, 28]. The apriori probabilities for the Bayesian Network are produced from the MulVAL attack graph representation using the approach in [28] and subsequent probability adjustments are made using new evidence from the security environment originating from the OWL security description. Finally, the decision analysis uses a game theory approach taken from [11] where mixed strategy games are produced using probability distributions describing how the attacker and defender choose over their pure strategy sets. By considering the costs of control implementation, using a cost matrix for both attacker and defender, optimum strategies are found for the defenders selection criteria.

The performance and usefulness of the framework is evaluated through both a statistical description of risk parameter handling and discussion with industry peers on the results of the decision outputs.

1.3 Structure

The dissertation consists of 5 chapters. The current gives the risk modelling approach and its relationship to the decision process. Chapter 2 introduces the necessary background information and discusses related work in the literature. Chapter 3 outlines the methods used to create and use the risk framework with details of experimental results presented in Chapter 4. Chapter 5 then discusses the results and assesses limitations.

Chapter 2

Background

For any network vulnerability analysis, consideration of how an attacker may combine threat events in an exploit has become an expected norm in the risk assessment process [34, 2]. A model is constructed using security states as variables with transitions between the states representing combinations of exploits. The assessor then attempts to find the most feasible attack path to a goal state (such as root access on a server) amongst the set of feasible states [3]. An attack graph [26] based on exploit dependencies is a common modelling tool, improving on the earlier approaches which treated the graphical elements independently [31]. The paper [21] by Albanese, Jajodia and Noel, introduced cost models for variable interdependence. Their paper introduces the concept of a critical set as a set of all exploits and conditions whose removal from the attack graph will negate all attack paths to a goal state. By realising that the initial conditions of attack vectors are not independent and creating an approximation algorithm that associates a cost with the hardening action (the control) for each element of a critical set, back propagation combined with monotonicity can choose an optimum path to a goal state based on the impact of the control selection on threat reduction. Attack graphs created in this way allow the removal of sub-optimal paths whilst retaining all information in the graph and keeping the computational requirements within a workable bound.

2.1 The Common Vulnerability Scoring System (CVSS)

A quantitative risk approach requires a statement of truth on which to build the risk framework. In this work, the CVSS scoring system was chosen as the statement of truth because the MulVAL attack graph toolkit contains a National Vulnerability Database

(NVD) MySQL sync mechanism which MulVAL adapters can use, with no fee, to translate vulnerability scan outputs into MulVAL analyzed input data which includes Common Vulnerability and Exposure Ids (CVEs) and subsequently CVSS base scores [25]. The CVSS score consists of a base, temporal and environmental component metric and is a number on a scale 1 - 10. The base score is normally modified manually, using the temporal and environmental metrics, as part of a Red Team modelling exercise [13] to define the threat landscape.

2.2 Attack Graph Representation Using MulVAL

The sample network in Fig 2.1 and the resulting attack graph produced using the MulVAL tool, provide a useful illustration of the approach.

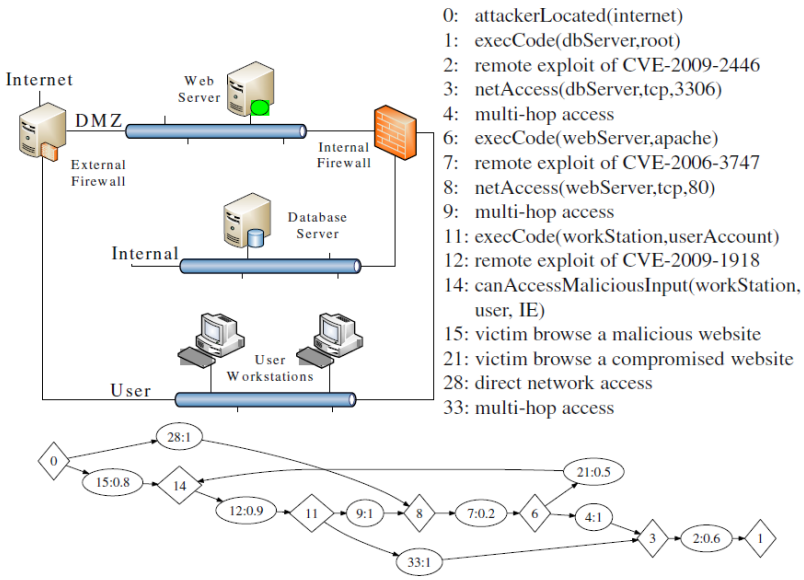


Figure 2.1: Example attack graph [34]

There are three types of vertices in a MulVAL attack graph. The elliptic vertex represents an attack-step which exploits a system vulnerability and can lead to a system state change, such as privilege escalation. The diamond vertex represents the state achieved. In MulVAL, a third type of vertex (a rectangle, omitted from Fig 2.1 but shown in Fig 2.2) represents facts about system configuration. The attack is only possible when all preconditions are in place. The incoming arcs to an attack step (elliptic node) therefore form a logical AND relation. Similarly, the incoming arcs to a privi-

lege state node show that there are multiple ways to achieve this change of state and form a logical OR relation. The reasoning engine in MulVAL uses Datalog [33] which builds a knowledge base of facts which are represented as Prolog horn clauses. A part of the knowledge base producing the attack graph in Fig 2.1 is shown below.

```
execCode(dbServer,root ) :-
    vulExists(dbServer, CVE-2009-2446, Oracle, remote, privEscalation),
    netAccess(dbServer, tcp, 3306),
    netAccess(dbServer, tcp, 80).
```

The knowledge base is made up of many such horn clauses which capture system configuration, firewall rules, vulnerabilities (e.g. from a nessus scan engine output) and other system facts. The Prolog system evaluates input tuples using Datalog. An example of a simple attack graph showing the logic relations between the system configuration, the exploits based on vulnerabilities and the privilege level achieved is shown in Fig 2.2 below. The set of nodes and arcs in the attack graph form a directed

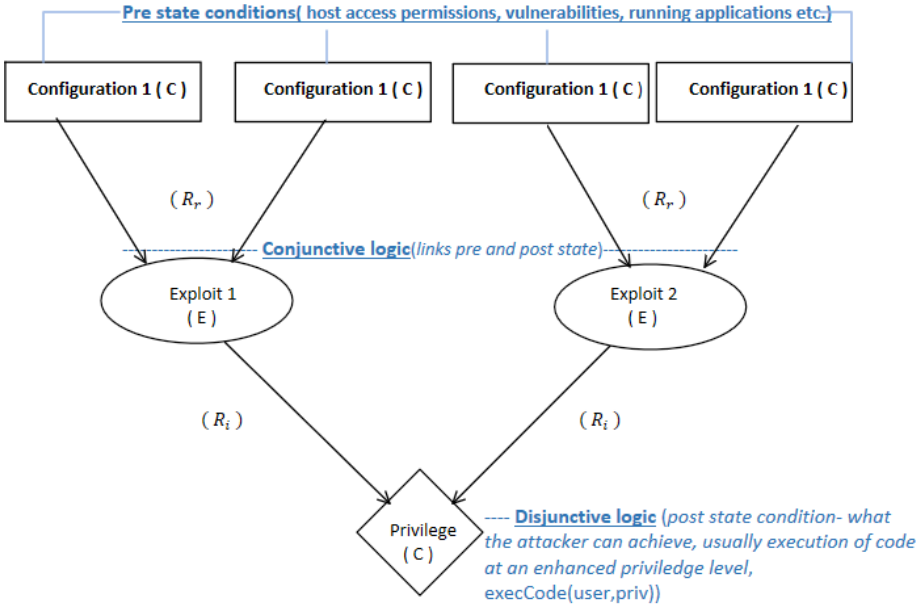


Figure 2.2: Logic structure of attack graph

graph $G(E \cup C, R_r \cup R_i)$ where E is the set of exploits and C the set of conditions with $R_r \subseteq C \times E$ and $R_i \subseteq E \times C$ being edges from preconditions to exploits and from exploits to goal conditions respectively. By combining multiple attack inter-dependencies reaching the same goal condition in this way MulVAL produces a polynomial time algorithm rather than the exponential time order involved when enumerating each attack

path individually. [21].

Attack graphs generated by the MulVAL tool require, as input, an input.P file which is a Datalog / Prolog representation of a network architecture and identified vulnerabilities. The input file is loaded into XSB (https://en.wikipedia.org/wiki/XSB) which provides tabled execution of Prolog programs. The objective is then to evaluate a security posture for its effectiveness given a set of security controls. MulVAL, as part of its toolkit, provides unix shell scripts to render and visualise the attack graph using the methods above. The arcs and nodes of the graph are stored in ARCS.csv and VERTICES.csv (Fig 4.2) and the graphviz utility is used to produce a visualisation of the graph (Fig 4.3).

2.2.1 Adding Probabilities to the Attack Graph

The paper [32] proposes a probabilistic metric which combines measurements of vulnerabilities obtained from existing metrics (such as the CVSS scoring system) to produce an overall score for the network. The approach uses, as a starting point, the relative likelihood of independent vulnerability exploits (when all the conditions of the scoring system are met) then develops and combines causal relationships inherent in the attack graph using the product rule of probability and the monotonicity condition, to produce a more representative measure of exploit likelihood on a particular attack graph path. To assign probabilities, the MulVAL toolkit uses this papers approach. The 'ProbAssess.sh' script calculates static probabilities for each vulnerability node in the attack graph based on the 'exploitability' metric of the CVSS scoring for that vulnerability normalised over the entire attack graph. The metric used by CVSS is [24]:

$$exploitability \equiv 20 \times (attackComplexity) \times (accessVector) \times (authenticationMetric)$$

Cumulative scoring (Fig 2.3) assumes independence of exploits and uses the causal relationships between conditions and exploits discussed above. In this way an apriori state (probability distribution) for the entire threat model is represented in the MulVAL attack graph. The logic path is as follows, the localised score is assigned from the CVSS exploitability metric.

Let e be associated with an exploit and c with a condition. Two sets of probabilities are produced $p(e)$ and $p(c)$ are assigned for the localised score (the likelihood

of exploit execution given all conditions are satisfied) and $P(e)$ and $P(c)$ are deduced for the cumulative score (the overall likelihood an attacker can successfully exploit a vulnerability in the attack graph given the inherent knowledge the graph contains). The normalised cumulative scores will be used in this dissertation as the initial apriori states of Bayesian nodes when forming the Bayesian network (section 2.3). The cumulative scoring is achieved by using the 'ProbAssess.sh' shell script.

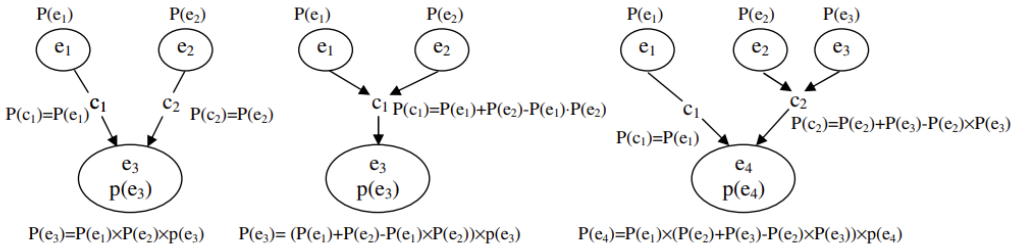


Figure 2.3: Cumulative probability factors

[32]

2.3 Extending the Attack Graph to a Bayesian Network

The attack graph formation above does describe the causal relationship between a systems vulnerabilities and does give a static probability for a vulnerability being exploited based on the CVSS exploitability metric. However, this view of security without relevant environmental context is not suitable for today's networks [28]. Additional constraints: financial restrictions, patching latency and organisational preferences such as functionality over security, mean that a more dynamic probabilistic approach capable of adjusting apriori probabilities to provide a posterior distribution based on information describing the security environment is required.

In this dissertation, the initial static probability score assigned, by MulVAL, for each node of the attack graph becomes an attribute of a Bayesian Network described by a Bernoulli random variable which gives a likelihood for the success of the particular atomic attack action at that node. The nodes then form a superposition of marginal discrete probability distributions which can be decomposed into factors and used to produce a posterior distribution. Nodes are then updated using forward propagation, based on updated evidence in the parent nodes (supplied via the Owlready2.0 and SMILE api), or via back propagation which adjusts the prior attributes which modifies

the likelihood of the expected outcomes. Various algorithms are available within the GeNie tool (https://www.bayesfusion.com) for belief updating of Bayesian networks including, message passing, stochastic simulation and junction tree graph reduction. The default algorithm, junction tree, is used in this report.

2.3.1 Interpreting the Bayesian Network

Bayesian networks provide a mechanism for investigating the causal relationships between variables based on probabilistic reasoning. However, the discovery algorithms used are themselves causal leading to a requirement for interpretation [19]. In this work, the relative strengths of causal relationships which create the posterior distribution follow an interpretation defined through the following techniques.

Markov blankets of key nodes. (Fig 2.4) - Show the independence domain and sphere of influence of nodes (neighbourhoods).

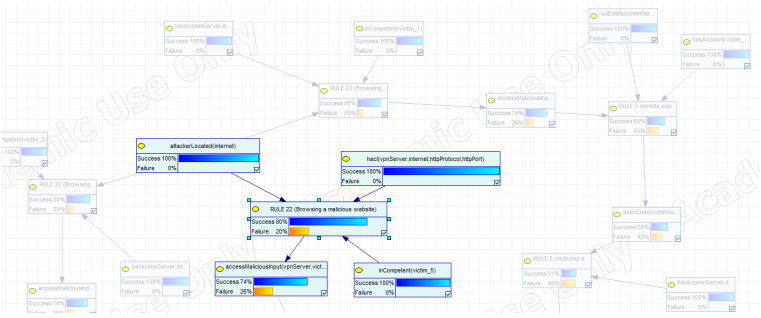


Figure 2.4: A Markov blanket independence set.

Arcs - Show the information and causation flow between two nodes.

Arc reversal. -Can illustrate direction of probabilistic influence. Conditional probability tables(CPTS) are recalculated so that the overall posterior distribution of the network remains unchanged.

Node Marginalization. - Combining nodes produces a structural transformation that finds the marginal distribution across the remaining nodes which preserves the original joint posterior probability.

Entering observations. -Information entered into the network updates belief (posterior distribution).

Controlling values. -External mechanisms can change network structure but you cannot change the descendant of an observed node as this means changing the past.

Virtual Evidence. -Entering evidence about latent variables affects the node over the states of the observation. Different evidence states can be entered by using the virtual evidence function in GeNie.

Strength of Influence (Fig 2.5). -Shows, in bold, the arcs with greatest strength of influence between the nodes. This represents the distance between the conditional probability tables over the child nodes conditional on parent states.

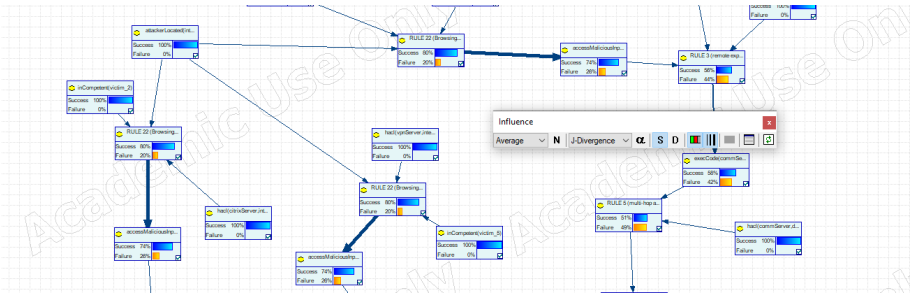


Figure 2.5: Strength of Influence.

Sensitivity Analysis. - Identifies the most sensitive parameters of a BN. These parameters affect the reasoning results significantly and identifying them allows targeted application of effort for optimum accuracy. Target nodes are selected and the tornado function in GeNie determines ranked parameter nodes affecting the posterior distribution of targets (see Fig 4.14 in Results).

2.4 Using OWL to provide a security knowledge base

To introduce a risk perspective, the paper [28] by Szpyrka et Al, provides a quantitative approach to managing risk using MulVal attack graphs and Bayesian networks and presents a strategy for dynamically assessing risk based on security attributes described via XACML (”eXtensible Access Control Markup Language”). Ideas from this

paper are extended in this dissertation by using the OWL description logics framework, instead of XACML, as a more extensive and structured knowledge base for security information and by using Python rather than Java to link the OWL and SMILE (GeNie) APIs.

Security controls are derived from information security standards such as ISO/IEC 27001 [16] and implemented as an assets protective measure in a vulnerability mitigation response. The need for a clear semantic description of security is discussed in [20] and the earliest representations of security control frameworks in an ontological form appear in [10, 14]. The W3C Web Ontology language OWL-DL [1] provides a description logics framework which can represent security knowledge in a standardised, hierarchical form and the paper [9] further extends the hierarchy of an OWL ontology to an acyclic graph and Bayesian network by the creation of bridging classes. This project's use of ontologies is primarily concerned with small scale, agile security representations and the primary paper for the development approach is [12] which discusses integration of logical and probabilistic knowledge bases realised through ontology-orientated programming and the Owlready2.0 python module. The paper's main concern is turning the reasoning inherent in the OWL information hierarchical structure into a model based on Bayesian reasoning. The approach used here instead turns the MulVAL attack graph into a Bayesian model then uses the Owlready2.0 API to update this Bayesian model with information from the OWL ontology.

2.4.1 Cyber Essentials as an Ontology

To gauge the effectiveness of a security strategy, a means of defining security policy and countermeasures is required. Early approaches to security ontology creation include Herzog [14] which creates a very involved ontology but which is not standards driven. Fenz [10] on the other hand, uses OWL and description logics to model the ISO27001 compliance framework. This dissertation chooses to model combinations of the control themes put forward in the Cyber Essentials certification standard, specifically the 'Requirements for IT infrastructure' publication [8]. Themes used in the standard are:

- Firewalls
- Secure Configuration(Device hardening)

- User Access Control (authentication and authorisation)
- Malware Protection (Anti-Virus, IPS and IDS etc.)
- Patch Management

The Cyber Essentials standard (CE) was developed specifically to help SME businesses achieve a recognised security certification which could directly aid the procurement process for government contracts and is chosen here because it is significantly less wieldy than ISO27001. In an enterprise setting, the ontology can model a wide selection of environmental controls including the subjective judgement of expert opinion on levels of staff competence, browsing habits etc. Development of a representative ontology which can describe the standard and aid risk assessment may help the uptake of CE.

2.5 Making decisions using Game Theory

Following risk assessment, decisions need to be made. The approach outlined in (Hankin, Fielder) [11] uses quantitative risk outcomes coupled with a cost model to inform threat countermeasure selection using attacker-defender two player games. The paper uses a measure of 'depth' as an abstraction of impact on a target due to a vulnerability. The resulting measure is based on the Confidentiality, Availability and Integrity of the data to be protected (the CIA triad). The approach to model abstraction in this report instead uses the CVSS measure of Impact to extend the mapping defined in (Viduto) [30] to a more granular calculation using information in the developed OWL ontology. In Viduto, the CIA triad is assigned an impact value of low, medium or high depending on the extent of component coverage (N=None, P=Partial, C=complete) [30]. For comparison, the impact scoring approaches used in both Viduto (Fig 2.6) and in the algorithm developed for this dissertation (Algorithm 1) are shown below. Impact is adjusted in the algorithm using a calculation based on the CVSS environmental scoring, imported ontology attribute values and the risk estimations from the corresponding Bayesian network random variable nodes. The adjusted impact score is then used in a cost function, the outputs of which populate the game input matrix used to find the Nash equilibria security policy (See Chapter 4 table 4.5).

$$I_i = \begin{cases} \text{Low}(10) & \text{when } \hat{\text{CIAI}}\{\text{NNP}, \text{NPN}, \text{PNN}\}; \\ \text{Medium}(50) & \text{when } \hat{\text{CIAI}}\{\text{PPN}, \text{PNP}, \text{NPP}, \text{PPP}, \text{NNC}, \text{NCN}, \text{CNN}\}; \\ \text{High}(100) & \text{when } \hat{\text{CIAI}}\{\text{PPC}, \text{PCP}, \text{CPP}, \text{NCC}, \text{CNC}, \text{CCN}, \text{PCC}, \\ & \text{CPC}, \text{CCP}, \text{CCC}\}; \end{cases}$$

Figure 2.6: Impact mapping using CIA triad (Viduto)

Algorithm 1 (Extract of Algorithm 2) Impact mapping using an ontology

$T := t_i$ ▷ set of assets/targets described in OWL

$V := v_z$ ▷ set of vulnerabilities found in attack graph

$D := d_x$ ▷ set of 'depths' - granular CIA abstraction in OWL

$t_i := (v_z, d_x)$

I:$T \leftarrow Z_{impact}$ ▷ Z is random variable of adjusted impact

Ensure: $\mathbf{I}(t_i) \leftarrow D$ ▷ adjusted impact at target depends on D

T:$T \leftarrow Z_{threat}$ ▷ Z is random variable of Bayesian nodes

Ensure: $\mathbf{T}(t_i) \leftarrow V$ ▷ whether asset is target depends on V

$\mathbf{L} := l_x \leftarrow CONTROL$ ▷ a control level is assigned in OWL

Ensure: $(l,t) \leftarrow mitigation(t_i)$ ▷ for a particular threat mitigation

$\mathbf{E} : \mathbf{L} \times \mathbf{T} \leftarrow [0,1)$ ▷ Metric for effectiveness of control selection

Require: $\mathbf{S}(l,t) = \mathbf{I}(t)\mathbf{T}(t)[1 - \mathbf{E}(l.t)]$ ▷ loss function(damage after control in place)

Chapter 3

Designing and Implementing the Framework

For reference, Fig3.1 shows a high level schematic diagram illustrating the component interactions described in this chapter and Appendix C summarises the tools used to construct and test the risk framework.

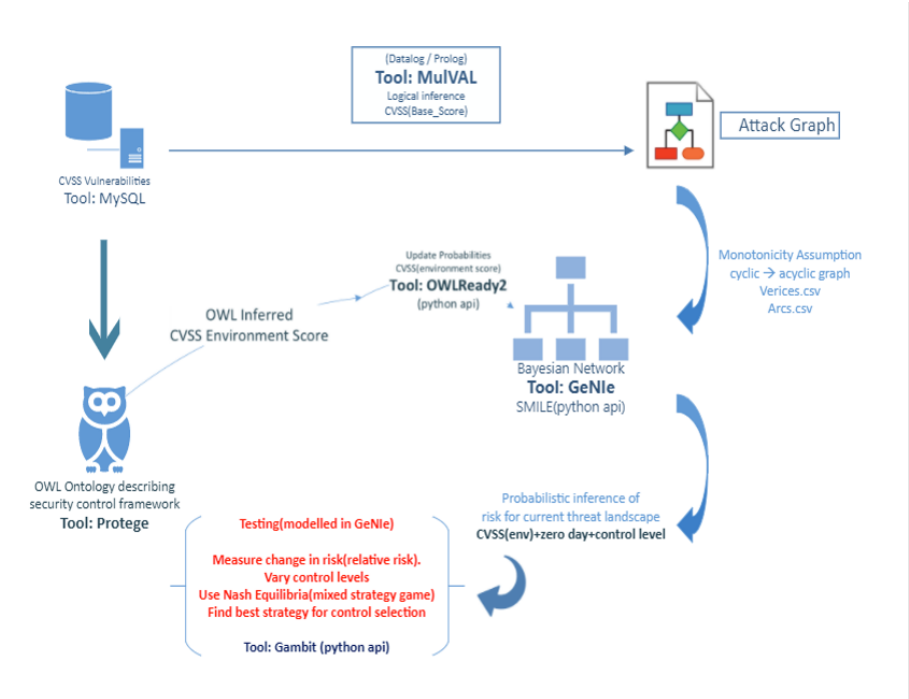


Figure 3.1: High level schematic of developed risk framework

3.1 Using MulVAL and Input Data Sources

MulVAL has a long list of dependencies including MySQL for storing the CVE vulnerabilities. Unfortunately, XML feeds (used by the MulVAL shell scripts to populate the database) are no longer available from NIST. A python script was used to populate the MySQL database with the latest CVE information from the NIST JSON feeds.

3.1.1 Creation of the input.P file

MulVAL requires as input, a Datalog file (input.P) containing many Datalog facts. These facts consist of: Advisories, host configuration, network configuration, principles and details of policy. Together they describe the model abstraction for the system. Examples of these constructs are shown below:

Advisories: vulExists(webServer, 'CAN-2002-0392', httpd) – models vulnerabilities
Host Config: networkService(webServer, httpd, TCP, 80, apache) – models hosts
Network Config: hacl(internet, webServer, TCP, 80) – models router and firewalls
Principles: hasAccount(user, projectPC, userAccount) – models bindings to user
Policy: allow(systemAdmin, write, webPages) – models access rights
Interaction: (Horn Clause, below) – models conclusions and conditions

```
execCode(Attacker, Host, Priv) :-
    vulExists(Host, VulID, Program),
    vulProperty(VulID, remoteExploit, privEscalation),
    NetworkService(Host, Program, Protocol, Port, Priv),
    netAccess(Attacker, Host, Protocol, Port),
    malicious(Attacker)
```

The command line syntax for running the program is:

```
# graph_gen.sh input.P -v -p
```

The input.P file is constructed by collating infrastructure and vulnerability information from Nessus scans as well as manual constructs. Translation of scan information (in XML format) to Datalog clauses uses the translation unix shell scripts which are part of the MulVAL toolkit (e.g. nessusXML_translate.sh). The architecture used in this dissertation is a modification of a test network scenario found on Su Zhang's ***westlifezs*** GitHub site `https://github.com/westlifezs/MulVAL/tree/master/`

`testcases/networkScenarios` shown in Fig 4.1. The procedure for creation of the input.P file largely depends on the infrastructure and the security environment. The overall steps are:

- Scan the infrastructure components using Nessus (XML format)
- Use nessusXML_translate.sh script to produce a nessus.P datalog file.
- Create other manual files as required. HACL policy rules etc.
- Collate all the input files into a Datalog input.P file.
- Run 'graph_gen.sh input.P' to produce the attack graph.

Because XSB uses dynamic, tabled execution, order is not important when collating the Datalog facts. An extract of the resulting input.P file with comments on the data origin is shown below for illustration. Attention is drawn to the manual modelling of human actors (blue font) and the vulnerability scan output automatically converted to datalog facts (red font). A full input.P file is shown in Appendix B.

```
Network topology and Policy: Manually created datalog policy facts.
hacl(internet, webServer, tcp, 80).
hacl(webServer, fileServer, rpc, 100003).
hacl(webServer, fileServer, rpc, 100005).
.
allow(Anyone, read, webPages).
allow(user, AnyAccess, projectPlan).
allow(sysAdmin, AnyAccess, Data).
.

Machine Configuration: Datalog tuples from the converted nessus.P scan
networkService(webServer , httpd, tcp , 80 , apache).
nfsMount(webServer, '/www', fileServer, '/export/www').
networkService(fileServer, nfsd, rpc, 100003, root).
.
.

Data Bindings: Manually created
dataBind(projectplan, workStation, '/home').
```

```
dataBind(webPages, webServer, '/www').
.
.

Principles: Manually modelled users and sysadmins setup on the platform.
hasAccount(user, workStation, userAccount). --- normal user
hasAccount(sysAdmin, workStation, root). --- administrator
hasAccount(sysAdmin, webServer, root).
hasAccount(sysAdmin, fileServer, root).
hasAccount(attacker, internet, root). -- attacker controls internet host
malicious(attacker). ---- the attacker

Vulnerabilities: Found from the translated Nessus scan (nessus.P)
vulExists(workStation, 'CAN-2004-0427', kernel).
vulExists(workStation, 'CAN-2004-0554', kernel).
vulExists(workStation, 'CAN-2004-0495', kernel).
vulExists(workStation, 'CVE-2002-1363', libpng).
.
vulProperty('CVE-2002-0392', remoteExploit, privEscalation).
vulProperty('CAN-2003-0252',remoteExploit, privEscalation).
.
.
```

3.2 Creating and using a Security Ontology

The purpose of the security ontology is to generalise a security policy for a network architecture and allow the evaluation of risk outcomes through changes in control selection and control metrics which define changes in security policy. The Owlready2.0 and the SMILE python APIs update the Bayesian network apriori values with information contained in the ontology allowing re-evaluation of risk via a superposition of posterior marginal probability distributions in the Bayesian network. The threat, control and vulnerability model implemented by the ontology is shown in Fig 3.2:

Ontology development uses the Protege application ((http://protege.stanford.edu) and follows the principles outlined in [22]. In practical terms, the ontology development proceeds by:

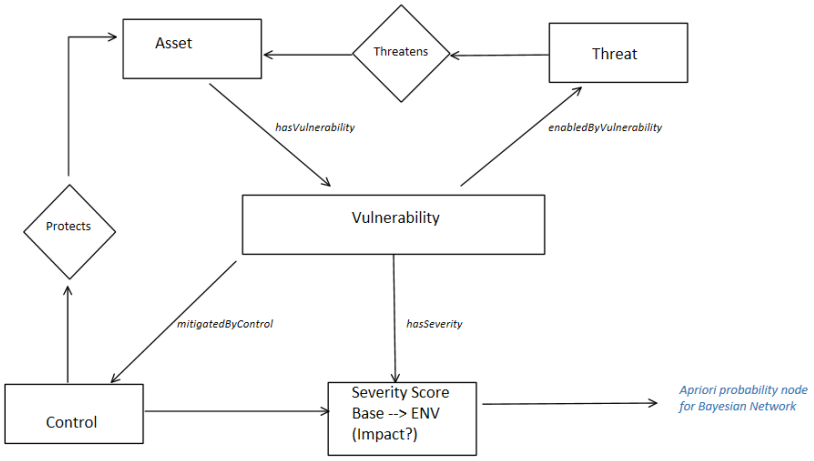


Figure 3.2: Threat mitigation model implemented by OWL ontology.

- Defining the object classes in the ontology.
- Arranging the classes in a subclass-superclass hierarchy.
- Defining variables and describing the allowed values.
- Filling in the variable values as they will be inherited by the class instances.
- Filling in the known variable values for defined instances.

For this work, eight different security policies based on varying choices of countermeasure attributes are mapped onto the ontology in turn. A particular security policy requirement is modelled by defining individual instances of the classes and filling in variable attribute value information coupled with restrictions as required. Countermeasures and control implementations defined in the ontology affect the probability of threats being realised and this information is updated in the Bayesian network via the SMILE and Owlready APIs.

3.2.1 Countermeasure strategies for security

The chosen countermeasures in the OWL security ontology define a security policy. A table of all OWL attributes with the possible CVSS adjustment levels is given in Appendix B. The instantiation of these countermeasures in the Protege GUI is illustrated in Fig 3.3 and Fig 3.4. To aid framework evaluation, the environmental modelling described in the developed ontology is limited to the CVSS base metrics of identified vulnerabilities and the corresponding control mitigations thus avoiding the inclusion

of subjective expert judgements as far as possible. The main exploit considered is privilege escalation on an identified vulnerable asset.

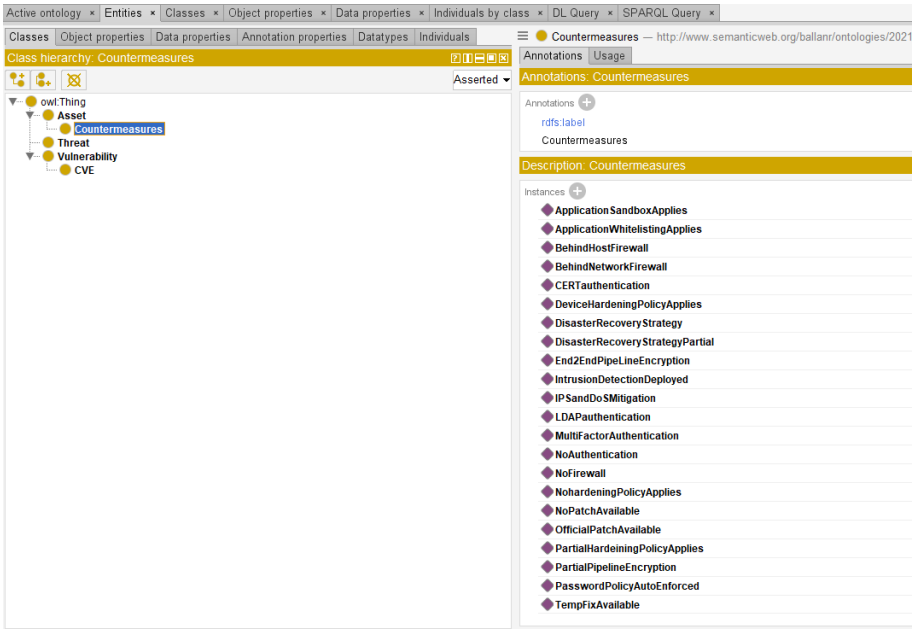


Figure 3.3: Instances of the Countermeasures class.

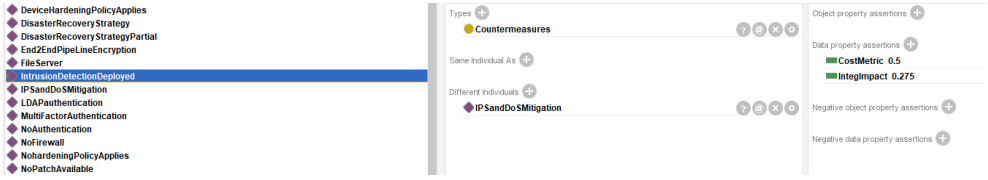


Figure 3.4: attributes of an IDS Countermeasure.

Cyber Essential Control	OWL Attribute	Effect on CVSS metric
Firewall	BehindNetworkFirewall(OOB or 2 factor auth)	AccessVector = adjacent = 0.646
Firewall	BehindNetworkFirewall(inband passwd admin)	AccessVector = adjacent = 0.73
Firewall	BehindHostFirewall(OOB or 2 factor auth)	AccessVector = local = 0.395
Firewall	BehindHostFirewall(inband passwd admin)	AccessVector = local = 0.52
Firewall	NoFirewall	AccessVector = network = 1.00
Secure Configuration	DeviceHardeningPolicyApplies(on build, with audit)	AccessComplexity = high = 0.35
Secure Configuration	DeviceHardeningPolicyApplies(on build, no audit)	AccessComplexity = high = 0.48
Secure Configuration	PartialHardeningPolicyApplies	AccessComplexity = Medium = 0.61
Secure Configuration	NoHardeningPolicyApplies	AccessComplexity = Low = 0.71
User Access Control	PasswordPolicyAutoEnforced	Authentication = Single = 0.56
User Access Control	NoAuthentication(password adhoc managed)	Authentication = none = 0.706
User Access Control	CERTauthentication	Authentication = multiple = 0.45
User Access Control	MultiFactorAuthentication	Authentication = multiple = 0.40
User Access Control	LDAPAuthentication	Authentication = multiple = 0.40
Malware Protection	IntrusionDetectionDeployed	IntegImpact = partial = 0.275
Malware Protection	IPSandDoSMitigation	IntegImpact = none = 0.075
Malware Protection	ApplicationWhitelistingApplies(audit and approval)	CollateralDamagePotential = low-medium = 0.3
Malware Protection	ApplicationWhitelistingApplies(audit, but user app install)	CollateralDamagePotential = low-medium = 0.35
Malware Protection	ApplicationSandboxApplies(to all unknown apps)	CollateralDamagePotential = low = 0.1
Malware Protection	ApplicationSandboxApplies(but not to all unknown apps)	CollateralDamagePotential = low = 0.2
Business Resiliency	DisasterRecoveryStrategy	AvailImpact = none = 0.0
Business Resiliency	DisasterRecoveryStrategyPartial	AvailImpact = partial = 0.275
Business Resiliency	End2EndPipeLineEncryption	ConfImpact = none = 0.0
Business Resiliency	PartialPipeLineEncryption	ConfImpact = partial = 0.275
Patch Management	Not Available at this time	will modify remediation level and temporal values

Table 3.1: Cyber Essential controls and CVSS scoring.

Fig 3.3 shows the complete list of countermeasures available, while Fig 3.4 shows a particular modelling for a partial IPS deployment countermeasure (CVSS Integrity impact score set to 0.275 and has an associated cost of 0.5).

The metrics used for modelling the Cyber Essential controls in Protege are shown in Table 3.1. The Attack graph generated by MulVAL shows the test infrastructure has known vulnerabilities on the Citrix server, the VPN server, the data historian and the Win2000 server. These vulnerabilities can lead, via the given structural interdependencies shown in the attack graph, to privilege escalation and malicious code execution (See Fig 4.2).

Eight security policies for evaluation against these vulnerabilities are constructed from the Cyber Essential controls described above.The first two policies are shown below. See Appendix B.2 for all eight security policies that were developed for this project.

Key

:Policy description

:OWL attribute describing CVSS metric value.

POLICY 1

Uses extensive firewall control at the perimeter and Citrix over IPSEC remote access.

Access is behind a network firewall but no host firewalls are used(BehindNetworkFirewall)

Citrix is used for external access to the Win2000 server(End2EndPipeLineEncryption)

RSA two factor authentication is used on Win2000 and VPN servers(MultiFactorAuthentication)

A Patching strategy is not to be used at present(NoPatchAvailable)

A full disaster recovery strategy is in place using resilient architecture(DisasterRecoveryStrategy)

No IDS or IPS is used on the network at this time.

Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)

No application whitelisting or sandbox is used.

POLICY 3

This approach uses a more porous firewall perimeter with host firewalls deployed extensively. The internal Citrix connectivity to the windows server is unencrypted. A patching policy is not in place but device hardening is fully implemented and controlled. Partial disaster recovery measures are used.

Access is behind a network firewall with host firewalls also used(BehindHostFirewall)

Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)

LDAP authentication is used on the Win2000 server and Radius at VPN(LDAPAuthentication)

A Patching strategy is not to be used at present(NoPatchAvailable)

There is a partial disaster recovery strategy in place(DisasterRecoveryStrategyPartial)

No IDS or IPS is used on the network at this time.

Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)

No application whitelisting or sandbox is used.

3.3 Forming and Updating the Bayesian Network

The attack graph is converted to a Bayesian Network (BN) using the GeNie tool from BayesFusion (`https://www.bayesfusion.com`). The ARCS.csv and VERTICES.csv generated as output by MulVAL already contain apriori probabilities as described in section 2.1.1 above. The resulting BN consists of a set of atomic attacks defined across the set of attributes described in the MulVAL datalog representation. The apriori state of the BN consists of system characteristics, threat sources and attacker capabilities. The input nodes can be adjusted using 'virtual evidence' which is a probability distribution rather than a deterministic evaluation over the node outcomes.

This is entered into the model by adjusting the certainties contained in the representation. For example, the 'incompetent victim' random variable in Fig 3.5 is initially modelled at 100% but through expert discussion this may be presented as a more representative probability (e.g. 0.94). Narrowing uncertainty through virtual evidence allows further marginalisation of nodes in the network which can aid understanding of the risk behaviour (using the techniques of section 2.3.1)

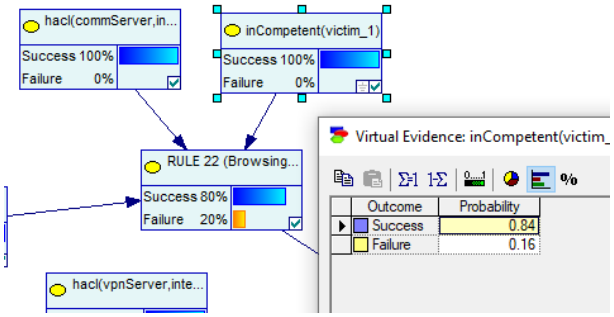


Figure 3.5: Adding evidence to Bayesian Network .

3.4 Cost and Decision making

Having produced risk outcomes based on differing vulnerability mitigations, it remains to make decisions on the best strategy to deploy. To do this a representative cost metric is needed. Both direct costs (fraction of the Budget used in implementation of the chosen control) and indirect costs (system performance, user moral, retraining costs associated with the control choice etc.) need to be assessed. An organisation should construct its own cost matrix from which a normalised cost value can be produced and used in determination of the loss function. The paper [30] contains a detailed exposition on creating a useful cost function for a particular business model. This dissertation is not concerned with the details of how costs are accurately modelled and a simplified approach is used to inform the cost function. Both direct and indirect costs are collapsed into a metric that represents a percentage of available budget. In illustration, if our budget is £200000 and the cost of an IDS system is £20000, then the cost metric for the IDS countermeasure is set in the OWL ontology as 0.2 or 0.3 with an adjusted 10% ongoing running cost. The setting of a cost metric in the OWL ontology is shown in Fig 3.4.

3.4.1 The Decision making strategy

A mixed strategy game, as described in [15] is motivated as a decision tool to choose the optimum security policy from a set of policies. To illustrate the atomic decision process, a simple two level attacker(A) and defender(D) game is shown in Fig. 3.6 [15]. θ is the probability of an adversary attacking a target t_i. The full algorithm developed for this dissertation, from risk evaluation to decision analysis, is shown as Algorithm 2 below. The Gambit tool `http://gambit.sourceforge.net/` is

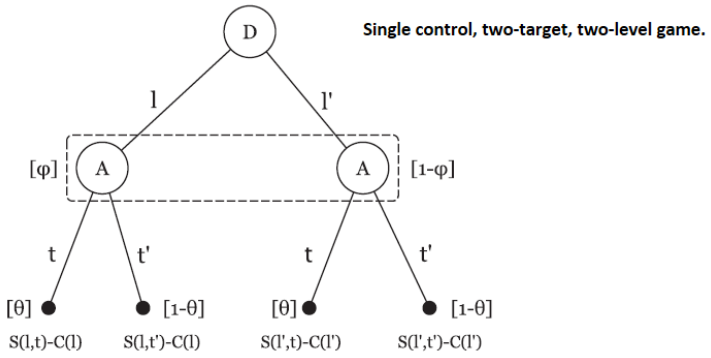


Figure 3.6: use of Loss function, S(l,t) - C(l), as decision maker.

used to formulate the zero-sum games where the attacker tries to inflict the maximum damage to the defender. In formulating the game, the pure strategy set for the defender is $\mathbf{L} := l_x$ (the control implementation level from the model ontology) and the pure strategy for the attacker is $\mathbf{T}(t_i)$ (the set of all vulnerabilities identified in the attack graph). The defender's goal is to chose the Nash cybersecurity plan from the 8 security policies. This is the security control strategy that will present the lowest risk for the defender when the attacker strategy is not known but assumed optimal. The zero sum game values in the sub games matrix (Section 4 Table 4.5) come from $\mathbf{Total_Loss} := \sum_{n=1}^{t} \mathbf{S}(l,t) - [direct\ and\ indirect\ costs]$ (see Algorithm 2).

Algorithm 2 Full Model Strategy

$T := t_i$ ▷ set of assets/targets described in OWL

$V := v_z$ ▷ set of vulnerabilities found in attack graph

$D := d_x$ ▷ set of 'depths' - granular CIA abstraction in OWL

$t_i := (v_z, d_x)$

I:$T \leftarrow Z_{impact}$ ▷ Z is random variable of adjusted impact

Ensure: $\mathbf{I}(t_i) \leftarrow D$ ▷ adjusted impact at target depends on D

T:$T \leftarrow Z_{threat}$ ▷ Z is random variable of Bayesian nodes

Ensure: $\mathbf{T}(t_i) \leftarrow V$ ▷ whether asset is target depends on V

$\mathbf{L} := l_x \leftarrow CONTROL$ ▷ a control level is assigned in OWL

Ensure: $(l,t) \leftarrow mitigation(t_i)$ ▷ for a particular threat mitigation

$\mathbf{E} : \mathbf{L} \times \mathbf{T} \leftarrow [0,1)$ ▷ Metric for effectiveness of control selection

Require: $\mathbf{S}(l,t) = \mathbf{I}(t)\mathbf{T}(t)[1 - \mathbf{E}(l.t)]$ ▷ loss function(damage after control in place)

while $N \leq 8$ **do** ▷ evaluating 8 policies in total

Total_Loss $:= \sum_{n=1}^{t} \mathbf{S}(l,t) - [direct\ and\ indirect\ costs]$ ▷ Loss Vector

end while

▷ Motivate a mixed strategy game, $\mathbf{G}_{j\lambda}$:

$\mathbf{Q}_{j\lambda} = [q_{j0}, q_{j1}, ..., q_{j\lambda}]$ ▷ Defenders probability distribution

$\mathbf{H}_{jn} = [q_{j1}, q_{j1}, ..., q_{jn}]$ ▷ Attackers probability distribution

▷ q_{j0} is the probability of defender implementing control c_j at a level 0.

▷ h_{j1} is the probability of adversary attacking asset t_i when defender implementing control c_j at a level 1

▷ Optimise using Minmax function, $C(\mathbf{Q}_{j\lambda})$ is indirect costs and Γ is direct cost.

$$\max_z \min_{t_i} \{\{1 - \sum_{j=1}^{c} \sum_{\lambda=0}^{m} E(Q_{j\lambda}, t_i) z_{j\lambda}\} I(t_i) T(t_i) - \sum_{j=1}^{c} \sum_{\lambda=0}^{m} C(Q_{j\lambda}, t_i) z_{j\lambda}\}$$

$s.t. \sum_{j=1}^{c} \sum_{\lambda=0}^{m} \Gamma(Q_{j\lambda}), z_{j\lambda} \leq B$ ▷ Cost of optimum control is less than Budget

$and \sum_{\lambda=0}^{m} z_{j\lambda} = 1, z_{j\lambda} \in 0, 1, \forall j = 1, ...c.$ ▷ c = number of controls

3.5 The Framework as an Agile Design Pattern

The framework design attributes created are summarised in the UML pattern shown in Fig 3.7. This pattern can be used to steer an implementation of this risk framework as demonstrated in Chapter 4. The pattern can be used, combined with a project management tool such as Jira (https://www.atlassian.com/software/jira), as part of an agile delivery mechanism.

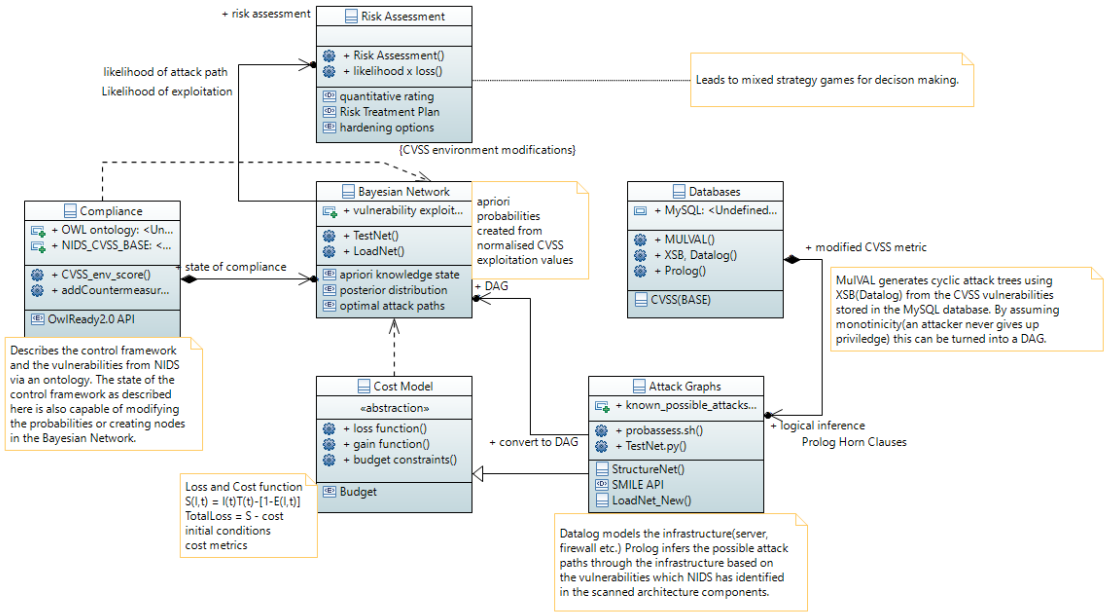


Figure 3.7: Risk Framework Representation

Chapter 4

Implementation and Evaluation

This chapter demonstrates use of the framework to secure a small test network (Fig 4.1). Eight different security strategies are considered and the framework used to choose the most appropriate strategy based on quantitative evaluation of the measured risk reduction in the threat landscape. The decision outcomes are evaluated using a combination of industry peer review and statistical methods. Script management is via GitHub (https://github.com/russellballantine/QuantitativeRisk_Framework) and scripts are arranged as follows:

Scripts using SMILE API

test_script.py – Acts as a backbone for running everything.

TestNet.py —– Creates the Bayesian Network structure from the Mulval Vertex and Arc CSV files.

StructureNet.py - Prints out the structure of the Net. Used by TestNet.py to get net structure.

LoadNet_New.py – Loads a network and updates it with new evidence from the ontology.

Scripts using Owlready2 API

CVSS_env_score.py – imports the ontology and updates the environment score.

addCountermeasures.py – adds the countermeasures configured in the OWL ontology. Imported by LoadNet_New.py

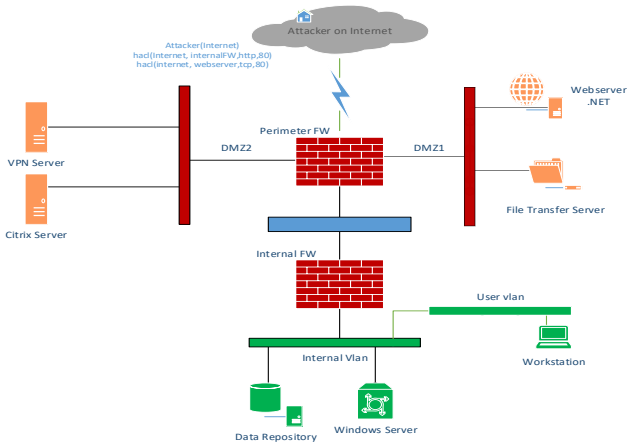


Figure 4.1: Example Test Infrastructure

4.1 Attack Graph Formation

The infrastructure is modelled using data log facts and converted vulnerability scan outputs as per Chapter 3 and the resulting input.P file (Appendix A) used with the MulVAL tool to generate attack graph data in the ARCS.csv and Vertices.csv files (Fig 4.3) which is used by graphviz to render the attack graph(Fig 4.2 and Appendix D)

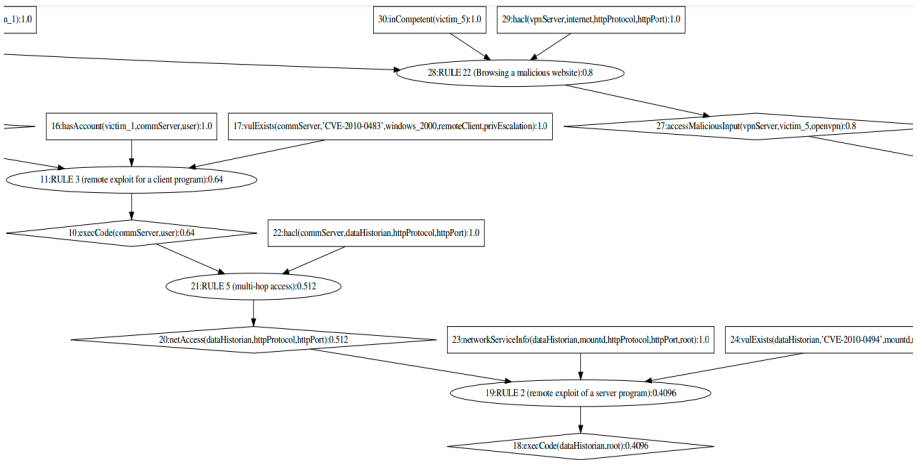
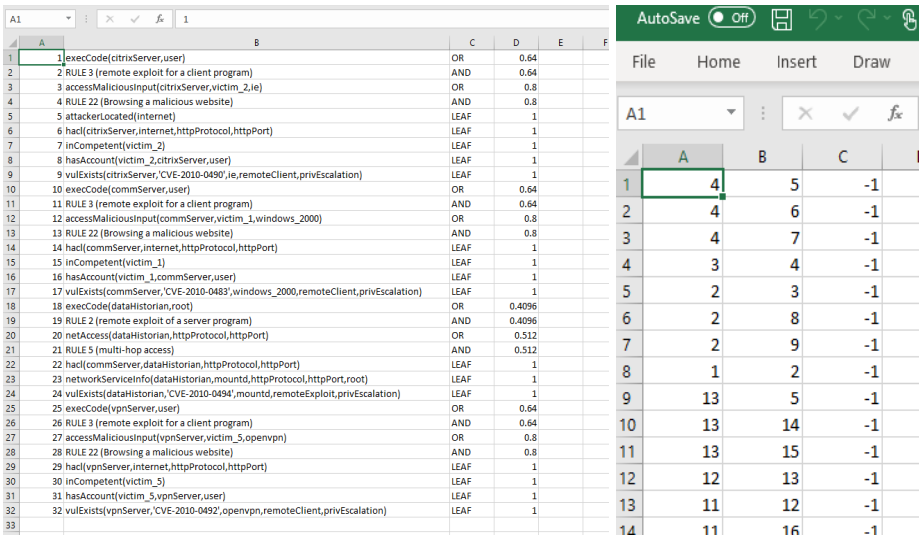


Figure 4.2: Partial attack graph with probabilities showing structural inter-dependencies of vulnerabilities CVE-2010-0494 and CVE-2010-0483.



	A	B	C	D
1	1	execCode(citrixServer,user)	OR	0.64
2	2	RULE 3 (remote exploit for a client program)	AND	0.64
3	3	accessMaliciousInput(citrixServer,victim_2,ie)	OR	0.8
4	4	RULE 22 (Browsing a malicious website)	AND	0.8
5	5	attackerLocated(internet)	LEAF	1
6	6	hacl(citrixServer,internet,httpProtocol,httpPort)	LEAF	1
7	7	inCompetent(victim_2)	LEAF	1
8	8	hasAccount(victim_2,citrixServer,user)	LEAF	1
9	9	vulExists(citrixServer,'CVE-2010-0490',ie,remoteClient,privEscalation)	LEAF	1
10	10	execCode(commServer,user)	OR	0.64
11	11	RULE 3 (remote exploit for a client program)	AND	0.64
12	12	accessMaliciousInput(commServer,victim_1,windows_2000)	OR	0.8
13	13	RULE 22 (Browsing a malicious website)	AND	0.8
14	14	hacl(commServer,internet,httpProtocol,httpPort)	LEAF	1
15	15	inCompetent(victim_1)	LEAF	1
16	16	hasAccount(victim_1,commServer,user)	LEAF	1
17	17	vulExists(commServer,'CVE-2010-0483',windows_2000,remoteClient,privEscalation)	LEAF	1
18	18	execCode(dataHistorian,root)	OR	0.4096
19	19	RULE 2 (remote exploit of a server program)	AND	0.4096
20	20	netAccess(dataHistorian,httpProtocol,httpPort)	OR	0.512
21	21	RULE 5 (multi-hop access)	AND	0.512
22	22	hacl(commServer,dataHistorian,httpProtocol,httpPort)	LEAF	1
23	23	networkServiceInfo(dataHistorian,mountd,httpProtocol,httpPort,root)	LEAF	1
24	24	vulExists(dataHistorian,'CVE-2010-0494',mountd,remoteExploit,privEscalation)	LEAF	1
25	25	execCode(vpnServer,user)	OR	0.64
26	26	RULE 3 (remote exploit for a client program)	AND	0.64
27	27	accessMaliciousInput(vpnServer,victim_5,openvpn)	OR	0.8
28	28	RULE 22 (Browsing a malicious website)	AND	0.8
29	29	hacl(vpnServer,internet,httpProtocol,httpPort)	LEAF	1
30	30	inCompetent(victim_5)	LEAF	1
31	31	hasAccount(victim_5,vpnServer,user)	LEAF	1
32	32	vulExists(vpnServer,'CVE-2010-0492',openvpn,remoteClient,privEscalation)	LEAF	1

	A	B	C
1	4	5	-1
2	4	6	-1
3	4	7	-1
4	3	4	-1
5	2	3	-1
6	2	8	-1
7	2	9	-1
8	1	2	-1
9	13	5	-1
10	13	14	-1
11	13	15	-1
12	12	13	-1
13	11	12	-1

Figure 4.3 MulVAL output files: Vertices.csv and Arcs.csv

4.2 A Simple Cost Function

To illustrate use of the framework, costs are modelled using the simple cost function approach suggested in section 3.4.

Assumption 1: All budget is fully allocated in all policies but may vary from policy to policy. The normalised cost per control, C(l,t), is found from:

$$C(l,t) = \frac{(cost\ of\ control)}{\sum_{per\ policy} (cost\ of\ all\ controls)}$$

where (l,t) are the control levels and targets as defined in algorithm 2. This allows the OWLready API to use the loss function, $L = S(l,t) - C(l,t)$, to update the BN with new control information.

Assumption 2: The *BehindHostFirewall* control assumes network firewalls are also deployed and therefore have a greater cost than *BehindNetworkFirewall*.

Costs used for testing are shown in Table 4.1:
The cost values for OWL countermeasure attributes are given in Table 4.2

Countermeasure	**Cost Value**
Network Firewall	£2000
Host Firewall (includes network firewall)	£3000
Citrix (encrypted)	£2000
Citrix (partial)	£1000
LDAP Authentication	£1000
Multi-factor authentication	£1500
Certificate authentication	£1250
Disaster Recovery(DR) strategy	£4000
Partial DR strategy	£3000
Device Hardening policy	£1000
Partial device hardening policy	£500
Official patching (man hours + subscription)	£1000
Patch(Temp fix only)	£500
IPS DoS Mitigation	£1000
IDS mitigation	£500
Application Whitelisting	£500
Application Sandboxing	£500

Table 4.1: Costs used for testing

OWL Countermeasure	**Normalised Cost per policy** $C(l,t) = \frac{\sum(cost\ of\ control)}{\sum(cost\ of\ all\ controls)}$	**Cyber Essentials Domain**
BehindNetworkFirewall	policy1,5 = 0.19 policy2 = 0.267 policy4 = 0.22 policy6 = 0.364 policy7 = 0.333	Firewall
BehindHostFirewall	policy3 = 0.33 policy8 = 0.3	Firewall
NoHardeningPolicyApplies	All policies = 0	Secure Configuration
PartialHardeningApplies	policy2 = 0.067	Secure Configuration
DeviceHardeningPolicyApplies	policy1,5 = 0.095 policy3,8 = 0.1 policy4 = 0.11 policy6=0.182 policy 7= 0.167	Secure Configuration
DisasterRecoveryStrategyPartial	policy2 = 0.4 policy3,4 = 0.33 policy5 = 0.286 , policy8 = 0.3	Secure Configuration
DisasterRecoveryStrategy	policy1=0.38	Secure Configuration
NoAuthentication	All policies = 0	User Access Contrl
LDAPauthentication	policy2 = 0.133 policy3,4 = 0.11 policy8 = 0.1	User Access Control
MultiFactorAuthentication	policy1 = 0.095 policy5 = 0.143	User Access Control
PartialPipeLineEncryption	policy2 = 0.133 policy3,4 = 0.11 policy5 = 0.095 policy6 = 0.182 policy7 = 0.167	User Access Control
End2EndPipeLineEncryption	policy1 = 0.19 policy8 = 0.2	User Access Control
IntrusionDetectionDeployed	policy6 = 0.091 policy7 = 0.083	Malware Protection
IPSandDoSMitigation	policy5 = 0.095	Malware Protection
ApplicationWhitelistingApplies	policy6 = 0.091	Malware Protection
ApplicationSandboxApplies	policy7 = 0.083	Malware Protection
NoPatchAvailable	All policies = 0	Patch Management
TempFixAvailable	policy6 = 0.091	Patch Management

Table 4.2: OWL countermeasure attributes

Asset	Identified Vulnerability	CVSS Threat Vector(ver.2)
Citrix Server	CVE-2010-0490	AV:N/AC:M/Au:N/C:C/I:C/A:C
Windows Server(2000)	CVE-2010-0483	AV:N/AC:H/Au:N/C:C/I:C/A:C
VPN Server	CVE-2010-0492	AV:N/AC:M/Au:N/C:C/I:C/A:C
Web Server	CVE-2002-0392	AV:N/AC:M/Au:N/C:C/I:C/A:C
Workstation	CVE-2010-0491	AV:N/AC:M/Au:N/C:C/I:C/A:C
File Server	CVE-2010-0812	AV:N/AC:L/Au:N/C:P/I:P/A:N

Table 4.3: Identified CVSS Threat Vectors

4.3 Evaluating risk reduction for policies 1-8

The attack graph shown in Fig 4.2 and Appendix D, identified the CVSS threat vectors (vulnerabilities) shown below. These vectors were subsequently used to populate the OWL ontology with the **base level** threat metric information using the NIST search utility at `https://nvd.nist.gov/vuln/search`

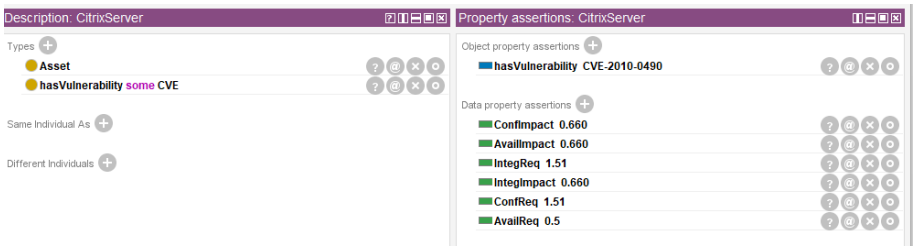


Figure 4.4: property assertions for AV:N/AC:M/Au:N/C:C/I:C/A:C

Fig 4.5 shows the Bayesian network prior to the application of any countermeasures (NewNet). Countermeasures are introduced to the model ontology by adding property

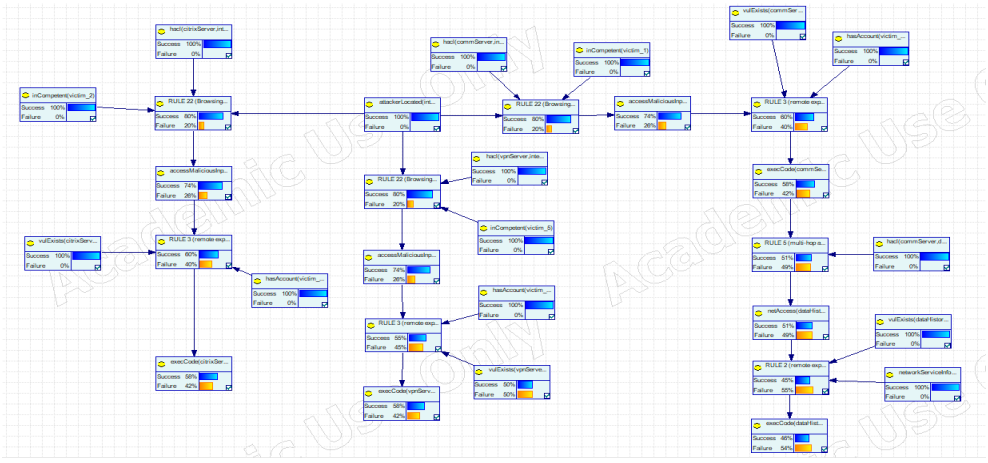


Figure 4.5: Bayesian Network prior to application of policy 1

assertions as mitigating actions on vulnerabilities. Fig 4.4 shows the assertions added

for CVE-2010-0490.

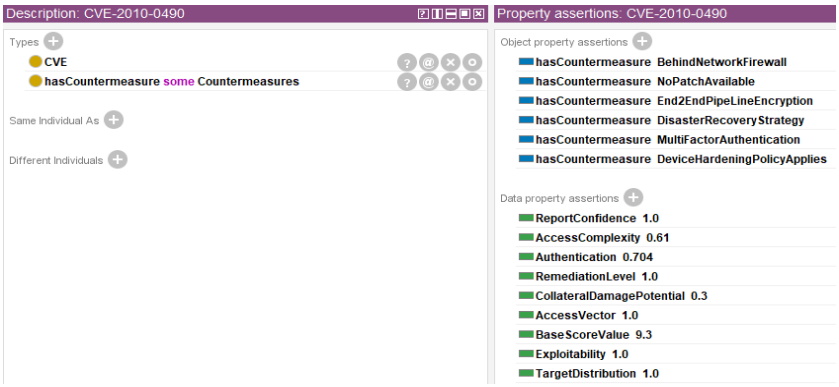


Figure 4.6: Addition of policy 1 countermeasures

OWLready2.0 and SMILE APIs provide an interface to update the BN with the ontology knowledge through the methods described in Chapter3. The BN updated after the application of Policy1 is shown in Fig. 4.10. Key output stages from the API modelling interface are shown in Fig 4.8 and Fig 4.9. Note that the BN vertex id (e.g. VRTX1) is identified from the properties of the BN node which can be viewed by changing the identifier on the BN from names to identifiers. To aid understanding of the API output below, an extract of the BN in this view is shown in Fig 4.7. This figure uses two different instances of the BN therefore the probabilities are different but the nodes align. Fig 4.8 shows selection of an asset (item 15 in OWL Individuals array, Citrix Server) and its corresponding vulnerability (item 10 in the OWL Individuals array, CVE-2010-0483). Calculation of environmental scoring is shown. Fig 4.9 shows the updating of VRTX1's CPT table based on changes in the VRTX2 node as a result of the new environmental scoring.

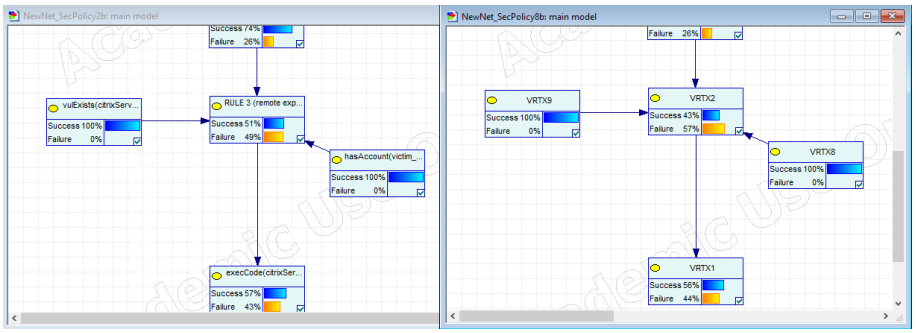


Figure 4.7: VRTX and Names identifiers

.

```
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++

Available Individuals are:
[ApplicationSandboxApplies, ApplicationWhitelistingApplies, AxwayFileTra
CVE-2010-0483, CVE-2010-0490, CVE-2010-0492, CVE-2010-0494, CVE-2010-081
DisasterRecoveryStrategyPartial, End2EndPipeLineEncryption, FileServer,
NoFirewall, NoPatchAvailable, NohardeningPolicyApplies, OfficialPatchAva
VPNServer, WebServer, Windows2000Server, WorkStation]

++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++


Enter Asset individual,100 to exit :15
Adjusted Impact Score is: 10

Enter vulnerability individual :10
Original Base Score is: 9.3
New Base score is: 6.14
Modified Temporal Score is: 6.1
Environmental Score is: 7.3
DeltaValue is: 0.8
Starting LoadNet_new...

Enter node to be adjusted for environment score, if none type 'none' :
```

Figure 4.8: Adjustment of network nodes

```
Enter node to be adjusted for environment score, if none type 'none' :VRTX2
Child node is: ['VRTX1']
CPT table of of child node is: [0.64 0.36 0.5  0.5 ]
Check modified CPT table: [0.512 0.488 0.5   0.5  ]
Updated CPT table: [0.512, 0.488, 0.5, 0.5]
Cyber Security loss at this control level(CSL): ['VRTX1', 2.4986]
Available classes are:
[Asset, CVE, Countermeasures, Threat, Vulnerability]

.....................................................................
```

Figure 4.9: Conditional probability table updates

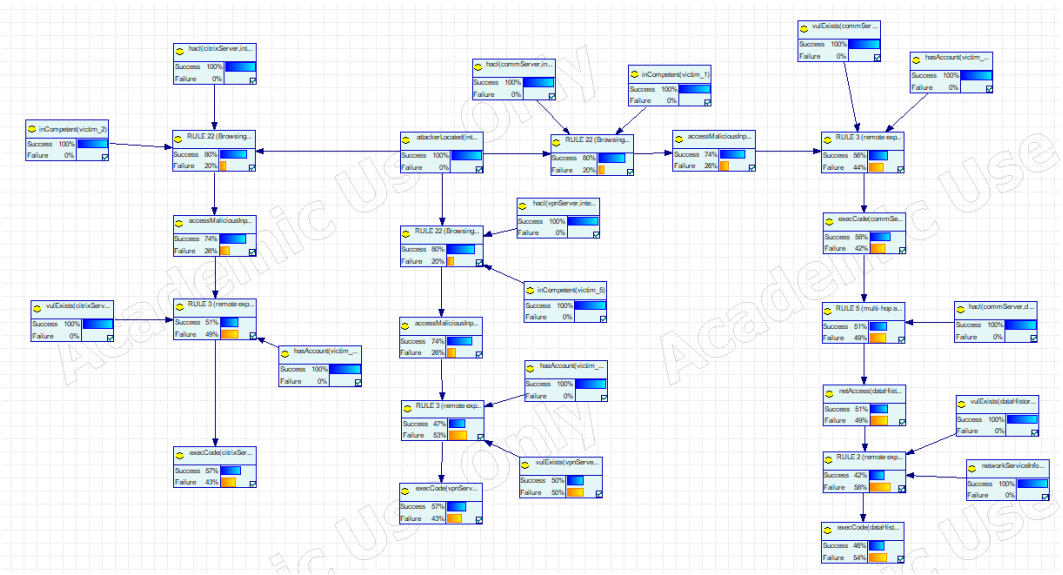


Figure 4.10: BN after policy1 applied

In Fig 4.11, the application of policy1 countermeasures has resulted in a 9% reduction

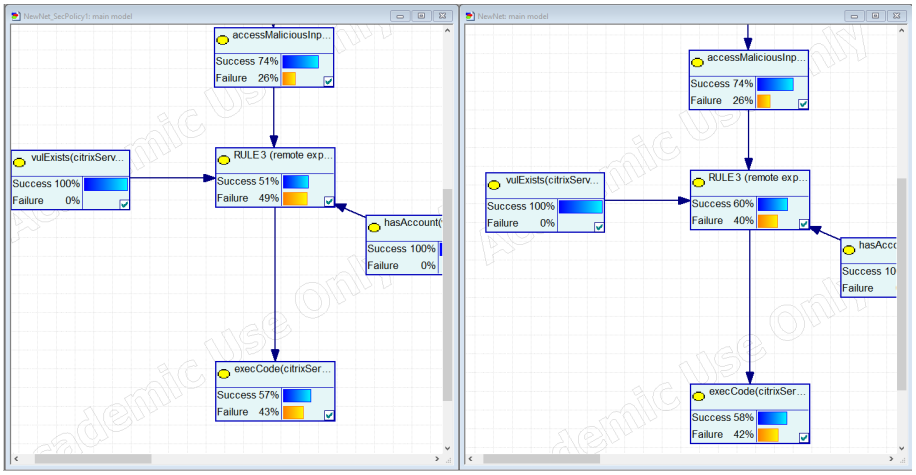


Figure 4.11: Comparing the Citrix server exploit branch after policy1 applied

in the probability of a remote client exploit state being achieved with a corresponding 1% reduction on the successful privilege escalation state on the Citrix server. The probability attributed to the execCode success exploit state (given an exploited client program) for each asset after policies 1 to 8 were applied is shown in the table 4.4. At this point in the framework process, it appears policy 8 provides the greatest percentage reduction in risk. However the cost of countermeasures, although calculated via the loss function (CSL in Fig 4.9) has not yet been incorporated in the risk reduction process.

Policy	Citrix	VPN Server	Comms Server	Data Historian
OriginNet	58%	58%	58%	46%
Policy1	57%	57%	58%	46%
Policy2	57%	57%	58%	46%
Policy3	57%	57%	58%	46%
Policy4	57%	57%	58%	46%
Policy5	58%	57%	58%	46%
Policy6	58%	57%	58%	46%
Policy7	57%	57%	57%	46%
Policy8	56%	56%	57%	46%

Table 4.4: Effect of policies 1-8 on exploit state

Policy	Citrix	VPN Server	Comms Server	Data Historian
Policy1	[2.50,-2.50]	[2.42,-2.42]	[2.44,-2.44]	[0.96,-0.96]
Policy2	[2.50,-2.50]	[2.43,-2.43]	[2.44,-2.44]	[0.96,-0.96]
Policy3	[2.50,-2.50]	[2.394,-2.394]	[2.46,-2.46]	[0.95,-0.95]
Policy4	[2.50,-2.50]	[2.42,-2.42]	[2.44,-2.44]	[0.96,-0.96]
Policy5	[2.50,-2.50]	[2.42,-2.42]	[2.44,-2.44]	[0.96,-0.96]
Policy6	[2.498,-2.498]	[2.47,-2.47]	[2.43,-2.43]	[1.05,-1.05]
Policy7	[2.485,-2.485]	[2.44,-2.44]	[2.48,-2.48]	[0.986,-0.986]
Policy8	[2.42,-2.42]	[2.334,-2.334]	[2.50,-2.50]	[0.95,-0.95]

Table 4.5: Game Input Matrix of zero-sum games

4.4 Using a game for policy selection

Zero-sum control games were formulated as per the methods of section 3.4.1 above. Code was included, using the SMILE API, to record the outputs of the $Total_Loss$ function which were then used to create a matrix of zero-sum games for use with the Gambit application. The matrix so formed is given in table 4.5. The figures in the square brackets are the equilibria at that node for the chosen control set. The game finds the Nash equilibria policy (optimum policy) from all control selection variances within the control's policy constraints. The outcome of this game produces a single Nash equilibria where the defender should choose policy 6 when the attacker's best strategy is against the Data Historian (Fig 4.12). The optimum decision outcome of the game is evaluated for stability using a simple sensitivity analysis as described in [36]. The results of this are shown in Table 4.6 and explained in section 4.5.

4.5 Evaluating the Risk and Decision Outcomes

A simple sensitivity analysis of the decision outcome was performed to examine the effects of changes to the pay off matrix on optimal strategy. The variable α represents a variance from the payoff value. Policy 6 is the dominant strategy for the defender

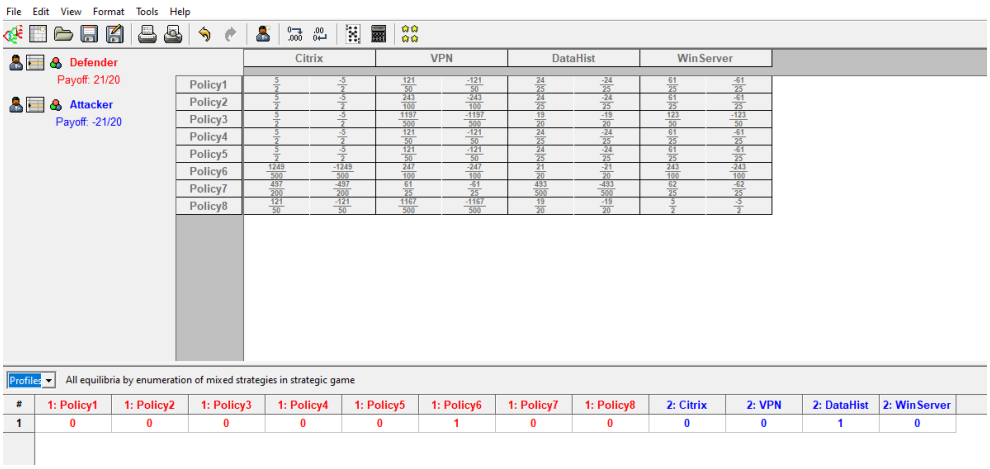


Figure 4.12: Nash equilibria from attacker - Defender game

payoff + α	α	Game Value	Decision
-21/20	0	21/20	policy 6
-20/20	0.05	1	policy 6
-199/200	0.055	0.995	policy 6
-197/200	0.065	493/500	policy 7
-39/40	0.075	493/500	policy 7
-19/20	0.1	0.983	policy 7

Table 4.6: Sensitivity analysis showing inflection between policy 6 and 7

when $-21/20 + \alpha \geq 0.986$. The value $493/500$ is an inflection point between policy 6 and 7. Using policy 6, target nodes (red nodes in Fig 4.13) representing privilege escalation on key assets were set in the Bayesian network and parameter sensitivity visualised using Genie's Tornado diagrams.

The Tornado diagrams provide sensitivity measurements and confidence intervals for the BN parameters (random variables) in the chain of probabilities leading to the leaf node. These probabilities can be considered risk ratios against a null hypothesis and corresponding t-statistic and P-values calculated to provide statistical measures of evidence against the null hypothesis. The values of the risk and decision outcomes from the experiment described here are summarised below along with the standard error, t-statistic and P-value calculated on the execCode(Data Historian) node (Table 4.7). Time permitting, it would have been useful to extend the sensitivity analysis along exploit paths in the Bayesian network to provide additional insights on where best to apply effort for additional security gains within the winning policy.

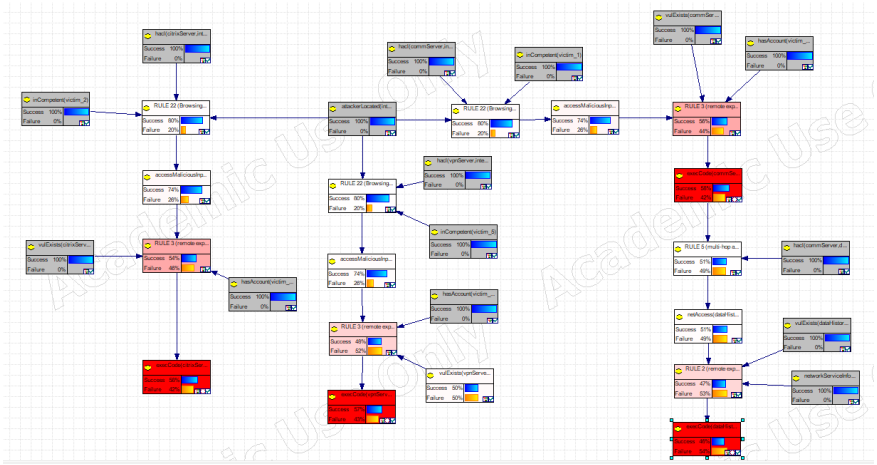


Figure 4.13: Target nodes for sensitivity analysis.

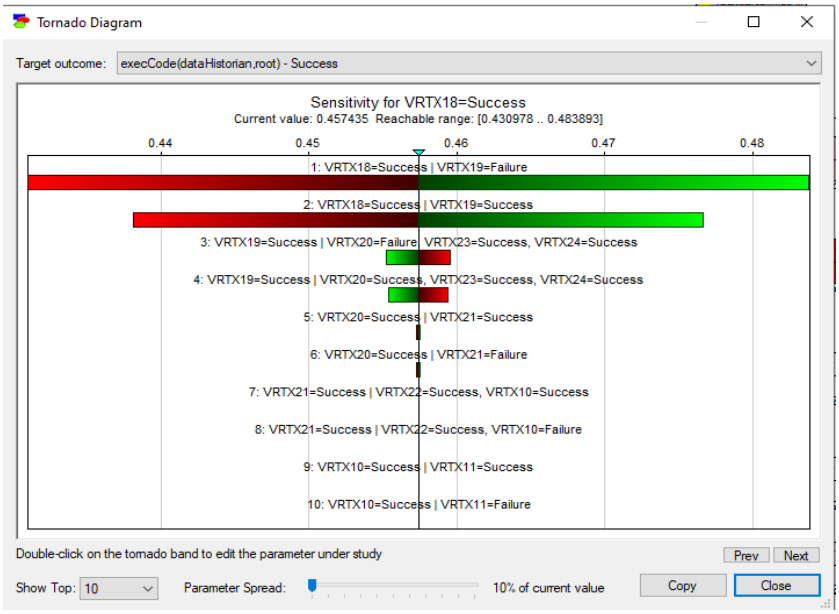


Figure 4.14: Parameter sensitivity for Data Historian exploit node.

Statistical Attribute	**Value**
Game outcome	Defender = Policy 6, Attacker = Data Historian
Target Node for sensitivity analysis	execCode(Data Hist)
Null Hypothesis	No code execution given privilege escalation
Risk Ratio (EST)	0.46 (value of random variable on execCode node)
Risk Range	0.431 – 0.484(confidence interval from tornado diag)
Confidence Interval	95%
Lower Bound (L)	0.431
Upper Bound (U)	0.484
Standard Error (SE)	$[-ln(L) - ln(U)]/(2 \times 1.96) = 0.116$
t-statistic (z)	$z = \frac{EST}{SE} = -6.69$ (take positive value)
P-value	$EXP[(-0.717 \times z) - (0.416 \times z^2)] = 6.74 \times 10^{-8}$
P-value < 0.0001	Null Hypothesis rejected, statistically significant.

Table 4.7: summary statistics for execCode(Data Historian)

Policy	Count
1	2
2	0
3	0
4	0
5	0
6	2
7	3
8	3

Table 4.8: Security policy choice peer review

4.6 Deterministic Policy Selection(Expert Opinion)

Due to time constraints, qualitative evaluation took place at the policy rather than control level with evaluators selecting what they considered to be the most appropriate security policy to secure the test infrastructure. Ten Industry security professionals were given a diagram of the test infrastructure (Fig 4.1), baseline costs (Table 4.1) and the descriptions of the 8 security policies (Appendix B.2) and asked to choose what they considered the most appropriate policy. This equates to evaluation of the final decision making process governing policy selection. The policy peer review summary (Table 4.8) shows policy 7 and 8 selected by 3 people ahead of the framework's choice of policy 6 (2 people selected this). Looking at the policies involved, policy 6 has a hybrid approach based on perimeter control and extensive end point security via application whitelisting and device hardening. Policy 8 would seem a reasonable intuitive choice implementing extensive perimeter security (network and host firewalls) as well as robust patching and authentication strategies. This was arguably the expected policy. However, the framework metrics have preferred extensive application whitelisting and a full device hardening policy ahead of perimeter security and robust authentication. These qualitative deductions can only have limited meaning with this level of analysis but, even so, provide some interesting insights for further discussion.

Chapter 5

Conclusions

The main goal of the project was to create a usable framework for quantitative evaluation of risk and this has been achieved. However, building a working framework model using the available open source tools has proven to be a time consuming and sometimes frustrating endeavour. Subjective assessment of the usefulness of the framework has been performed to some degree but with more time and access to suitable testing environments and personnel a more objective determination of usability would have been possible. The MulVAL toolkit uses XML based parsing tools but NIST and CVSS have discontinued XML vulnerability feeds in favour of JSON feeds. A method to convert the XML to JSON before importing into MySQL had to be found. Generating attack graphs using MulVAL relies on creating and using Datalog / Prolog clauses with automation scripts working on scan outputs and manual constructs. The manual component of the modelling proved time consuming. More recent attack graph tools are available which have better Red Team modelling capabilities but they are not free at the point of use. An ideal development and test environment would be a commercial SOC with licensed products available to build a full pilot model. The concepts developed in the framework should extend well to more commercialised and interconnected products. Current SIEM (Security Information and Event Management) tools, such as Microsoft Sentinel and VMware's Carbon Black, have introduced machine learning and graphical methods into their service offerings but the graphical approaches to threat and vulnerability handling tend to deal only with independent nodes as defined in the user created mappings at setup time. Some mechanisms are present in these products to apply policy and compliance constraints to the technical infrastructure but these are not full ontological descriptions and there is no decision making functionality built in. Outputs are in general intended to be fed to other downstream security tools

for correlation and contextual additions before being passed to SOC staff for actionable analysis. The ideas developed in this dissertation could be used to extend existing security frameworks and threat hunting capabilities to include: a more granular depiction of an organisational security policy giving greater environmental context and therefore greater accuracy in risk estimation, graphical methods that incorporate exploit dependencies rather than independent node values, and improved decision making to assist SOC team analysis.

In any quantitative risk based framework deciding on the statement of truth that will inform all metrics is fundamental. The framework developed here uses the equations of the CVSS v2.0 scoring system to calculate adjusted impact values but could be easily modified to use the newer CVSS v3.0 scoring metrics. The newer version has more granular base metrics which should allow a more effective ground truth for initial risk calculations. Small modifications to the SMILE and OWLReady APIs would allow the v3.0 scoring system to be used as the underlying truth.

The operational test environment and the use cases considered in this research were very simplistic. Evaluation of risk based on 'Zero-Trust' security models has lately become de-rigeur and context, based on changing levels of knowledge about participating actors, has become fundamental in assessing changing security posture. An ontological, semantic description of this changing environment, as provided by this work, enhances the ability to respond quickly and effectively to reassessing risk under these circumstances. An informed attacker may consider the most likely, easiest and cost effective attack path in an environment to also be the path with greater defences and subsequently direct attention based on reverse-logic to paths least likely and more costly. In attempting to gauge and model an attackers thought processes, the simple Nash equilibria mixed strategy games used in the frameworks decision making will need to give way to more elaborate gaming strategies. The framework already includes the interfaces to handle these more elaborate games. Another consideration is the threat provided by unknown vulnerabilities or zero-day exploits. The Bayesian Network created from CVSS scoring attack graphs, although not directly rendering causal representations of unknown malicious actors, does provide a means to extend the Bayesian network structure to an influence diagram and in doing so represent such a zero-day vulnerability alongside the logical architecture based causal constructions already present in the graph.

Bibliography

[1] W3C. OWL - web ontology language, February 2004.

[2] NIST Special Publication 800-30 Revision 1. Guide for conducting risk assessments. https://www.nist.gov/privacy-framework/nist-sp-800-30. Accessed: 2021-12-09, Revision 1. last updated April 2021.

[3] Ramakrishnan C. and Sekar R. Model-based analysis of configuration vulnerabilities. Journal of Computer Security. 10. 10.3233/JCS-2002-101-209. 2001.

[4] Biljana Cerin. Cyber security risk is a board-level issue. In *2020 43rd International Convention on Information, Communication and Electronic Technology (MIPRO)*, pages 384–388, 2020.

[5] Howard Chivers, Richard F. Paige, and Xiaocheng Ge. Agile security using an incremental security architecture. In *Extreme Programming and Agile Processes in Software Engineering*, volume 3556 of *Lecture Notes in Computer Science*, pages 57–65, Berlin, Heidelberg, 2005. Springer Berlin Heidelberg.

[6] Howard Chivers, Richard F. Paige, and Xiaocheng Ge. Agile security using an incremental security architecture. In Hubert Baumeister, Michele Marchesi, and Mike Holcombe, editors, *Extreme Programming and Agile Processes in Software Engineering*, pages 57–65, Berlin, Heidelberg, 2005. Springer Berlin Heidelberg.

[7] Paul Stokes Co-founder, CEO of Prevalent AI, and the Managed Security Forum. Counting on quantitative cyber risk. (https://www.infosecurity-magazine.com/ ‘ opinions/quantitative-cyber-risk). Accessed: 2022-22-07.

[8] Crown Copyright. Cyber essentials: Requirements for it infrastructure. https://www.ncsc.gov.uk/files/Cyber-Essentials-Requirements-for-IT-infrastructure-2-1.pdf. 2020.

[9] Zhongli Ding, Yun Peng, and Pan. *A Bayesian Approach to Uncertainty Modelling in OWL Ontology*. https://www.researchgate.net, publication:235154596 edition, 2006.

[10] Stefan Fenz and Andreas Ekelhart. Formalizing information security knowledge. In *Proc. of the 4th Intl. Conf. on Information, Computer, ALT '97*, pages 183–194, 2009.

[11] Malacaria P. Hankin C. Fielder A., Panaousis E. and Smeraldic F. *Decision Support approaches for cyber security investment.* Science Direct Journal, https://www.elsevier.com/locate/dss edition, 2016.

[12] Eko K. Budiardjo Foni A. Setiawan and Wahyu C. Wibowo. ByNowLife: A Novel Framework for OWL and Bayesian Network Integration. Information 2019, 10, 95; doi:10.3390/info10030095.

[13] Jacob G.Oakley. *Professional Red Teaming Conducting Successful Cybersecurity Engagements*. Springer Nature, isbn : 978-1-4842-4308-4 edition, 2019.

[14] Almut Herzog, Nahid Shahmehri, and Claudiu. Duma. *An Ontology of Information Security*. IEEE/IFIP International Conference on Dependable Systems and Networks, 10.4018/9781605662107.ch018. edition, 2009.

[15] Hoffman M Hitzig Z and Yoeli E. 14.11 insights from game theory into social behavior: Pure strategy matrix form games and nash equilibria. MIT OpenCourseWare. 2013.

[16] ISO/IEC. Iso/iec 27001:2005. Information technology - Security techniques - Information security management systems - Requirements, 2005.

[17] Lamy JB. *Ontologies With Python.* Apress, ISBN-13(pbk):978-1-4842-6551-2, https://doi.org/10.1007/978-1-4842-6552-9 edition, 2021.

[18] Bergin K. Hiscox insurance, web site. `https://www.hiscoxgroup.com/news/press-releases/2018/18-10-18`. Accessed: 2021-11-19.

[19] Kevin B. Korb and Ann E. Nicholson. *The Causal Interpretation of Bayesian Networks*, pages 83–116. Springer Berlin Heidelberg, Berlin, Heidelberg, 2008.

[20] Donner M. Toward a security ontology. IEEE Security and Privacy, 1(3): pp. 6-7, 2003.

[21] S.Jajodia M.Albanese and S.Noel. *Time-Efficient and Cost-Effective Network Hardening Using Attack Graphs*. IEEE/IFIP International Conference on Dependable Systems and Networks, pp. 1-12, doi: 10.1109/dsn.2012.6263942. edition, 2012.

[22] Natalya F. Noy and Deborah L. McGuinness. *Ontology Development 101: A Guide to Creating Your First Ontology*. Stanford University, Stanford, CA, 94305, noy@smi.stanford.edu and dlm@ksl.stanford.edu edition, 2000.

[23] R.Dewri N.Poolsappasit and I.Ray. *Dynamic Security Risk Management Using Bayesian Attack Graphs*. IEEE Transactions on dependable and Secure Computing, vol. 9, no. 1, pp. 61-74, 10.1109/tdsc.2011.34. edition, 2012.

[24] Forum of Incident Response and Security Teams. Common vulnerability scoring system version 3.1 user guide. `https://www.first.org/cvss/user-guide`. Accessed: 2021-11-19, Version 3.1. First, June 2019.

[25] Karen Scarfone Peter Mell and Sasha Romanosky. *A Complete Guide to the Common Vulnerability Scoring System Version 2.0*. Forum of Incident Response and Security Teams (FIRST), 2007.

[26] Lipmann R. and Ingols K. An annotated review of past papers on attack graphs. Tech. Rep., Lincoln Laboratory. 2005.

[27] Bernhard Rumpe. *Agile and UML-Based Methodology*, pages 9–31. Springer International Publishing, Cham, 2017.

[28] Wrona K. Szpyrka M., Jasiul B. and Dziedzic F. *Telecommunications Networks Risk Assessment with Bayesian Networks*. Lecture Notes in Computer Science, Vol 8104. Springer, Berlin, Heidelberg., https://doi.org/10.1007/978-3-642-40925-7-26. edition, 2013.

[29] Sam Trendall. Ncsc picks iot, cloud, and cryptojacking among uk plc's biggest future threats. *Public Technology*, Apr 10 2018. Copyright - Copyright Dods Parliamentary Communications Limited Apr 10, 2018; Last updated - 2018-04-10.

[30] Valentina Viduto, Carsten Maple, Wei Huang, and David. Lopez-Perez. A novel risk assessment and optimisation model for a multi-objective network security

countermeasure selection problem. Science Direct- Decision Support Systems. 53. 599-610. 10.1016/j.dss.2012.04.001. 2012.

[31] Lingyu Wang, Steven Noel, and Sushil Jajodia. Minimum-cost network hardening using attack graphs. Computer Communications. 29. 3812-3824. 10.1016/j.comcom.2006.06.018. 2006.

[32] Singhal A Wang L, Islam T and Jajodia S. An attack graph-based probabilistic security metric. V. Atluri (Ed.): DAS 2008, LNCS 5094, pp. 283–296, 2008. IFIP International Federation for Information Processing 2008.

[33] Wayne F. Boyer Xinming Ou and Miles A. McQueen. A scalable approach to attack graph generation. In *13th ACM Conference on Computer and Communications Security (CCS)*, pages 336–345, 2006.

[34] Anoop Singhal Xinning Ou. *Quantitative Security Risk Assessment of Enterprise Networks*. Springer Briefs in Computer Science, isbn: 978-1-4614-1860-3, - doi 10.1007/978-1-4614-1860-3 edition, 2011.

[35] Wenjun Xiong and Robert Lagerström. Threat modeling – a systematic literature review. *Computers and Security*, 84:53–69, 2019.

[36] Hamed Yarmanda and Kourosh Eshghi. Mathematical and computer modelling: Sensitivity analysis of matching pennies game. Elsevier Ltd. 2009.

Appendix A

MulVAL Input File

A.1 input.P file

```
/*Datalog model for test infrastructure (2 firewall)*/

attackerLocated(internet).
attackGoal(execCode(workStation,_)).
attackGoal(execCode(fileServer,_)).
attackGoal(execCode(vpnServer,_)).
attackGoal(execCode(dataHistorian, _)).
attackGoal(execCode(webServer, _)).
attackGoal(execCode(commServer, _)).
attackGoal(execCode(citrixServer, _)).


/*Network connections --- include the NFS protocols to cater for ax01 folder us
hacl(internet, webServer, tcp, 80).
%hacl(webServer, mailServer, nfsProtocol, nfsPort).
hacl(internet, vpnServer, httpProtocol, httpPort).
hacl(internet, citrixServer, httpProtocol, httpPort).
hacl(internet, commServer, httpProtocol, httpPort).
hacl(fileServer, workStation, nfsProtocol, nfsPort).
hacl(citrixServer, vpnServer, httpProtocol, httpPort).
hacl(vpnServer, citrixServer, httpProtocol, httpPort).
hacl(vpnServer, workStation, httpProtocol, httpPort).
```

```
hacl(workStation, vpnServer, httpProtocol, httpPort).
hacl(commServer, dataHistorian,httpProtocol, httpPort).
hacl(dataHistorian, commServer,httpProtocol, httpPort).
hacl(webServer, fileServer, httpProtocol, httpPort).
hacl(fileServer, webServer, httpProtocol, httpPort).
hacl(fileServer, workStation, httpProtocol, httpPort).
hacl(workStation, fileServer, httpProtocol, httpPort).
hacl(workStation, webServer, httpProtocol, httpPort).
hacl(webServer, workStation, httpProtocol, httpPort).

hacl(citrixServer, internet, httpProtocol, httpPort).
hacl(commServer, internet, httpProtocol, httpPort).
hacl(vpnServer, internet, httpProtocol, httpPort).
hacl(webServer, internet, httpProtocol, httpPort).

hacl(webServer, internet,  _, _).
hacl(mailServer, internet, _, _).
%hacl(workStation, internet, _, _).
%hacl(H,H,_,_).

/* configuration information of citrixServer */
vulExists(citrixServer,'CVE-2010-0490',ie).
vulProperty('CVE-2010-0490',remoteExploit,privEscalation).
vulProperty('CVE-2010-0490',remoteClient,privEscalation).
inCompetent(victim_2).
hasAccount(victim_2, citrixServer, user).

/* configuration information of commServer */
vulExists(commServer,'CVE-2010-0483',windows_2000).
vulProperty('CVE-2010-0483',remoteExploit,privEscalation).
vulProperty('CVE-2010-0483',remoteClient,privEscalation).
inCompetent(victim_1).
hasAccount(victim_1, commServer, user).

/* configuration information of vpnServer */
```

```
vulExists(vpnServer,'CVE-2010-0492',openvpn).
vulProperty('CVE-2010-0492',remoteExploit,privEscalation).
vulProperty('CVE-2010-0492',remoteClient,privEscalation).
inCompetent(victim_5).
hasAccount(victim_5, 'vpnServer', user).

/* configuration information of webServer */
vulExists(webServer, 'CAN-2002-0392', httpd).
vulProperty('CAN-2002-0392', remoteExploit, privEscalation).
%networkServiceInfo(webServer , httpd, tcp , 80 , apache).
isWebServer(webServer).
inCompetent(victim_7).
hasAccount(victim_7, 'webServer', user).

/* configuration information of dataHistorian */
vulExists(dataHistorian,'CVE-2010-0494',mountd).
vulProperty('CVE-2010-0494',remoteExploit,privEscalation).
%vulProperty('CVE-2010-0494',remoteClient,privEscalation).
%networkServiceInfo(webServer , httpd, tcp , 80 , apache).
networkServiceInfo(dataHistorian, mountd, httpProtocol, httpPort, root).

/* configuration information of fileServer */
%remote_client_vul_exists(fileServer,windows_2003_server).
vulExists(fileServer,'CVE-2010-0812',windows_2003_server).
vulProperty('CVE-2010-0812',remoteExploit,privEscalation).
vulProperty('CVE-2010-0812',remoteClient,privEscalation).
inCompetent(victim_3).
hasAccount(victim_3, 'fileServer', user).


/* configuration information of workStation */
%remote_client_vul_exists(workStation,acrobat).
vulExists(workStation,'CVE-2010-0491',acrobat).
vulProperty('CVE-2010-0491',remoteExploit,privEscalation).
vulProperty('CVE-2010-0491',remoteClient,privEscalation).
```

```
inCompetent(victim_4).
hasAccount(victim_4, 'workStation', user).
%nfsExportInfo(workStation, '/export', write, fileServer).

/*cvss metrics --- add the vulnerabilities identified through Phoenix ISR vulne
cvss('CAN-2002-0392',h).
cvss('CVE-2010-0483',h).
cvss('CVE-2010-0490',m).
cvss('CVE-2009-2503',m).
cvss('CVE-2010-0812',m).
cvss('CVE-2010-0491',l).
cvss('CVE-2010-0492',m).
cvss('CVE-2010-0493',m).
cvss('CVE-2010-0494',m).

/*Client side applications*/
isClient(httpd).
isClient(mountd).
isClient(windows_2003_server).
isClient(windows_2000).
isClient(openvpn).
isClient(firefox).
isClient(office_word).
isClient(itunes).
isClient(acrobat).
isClient(quicktime).
isClient('.net_framework').
isClient(office_frontpage).
isClient(flash_player).
isClient(adobe_air).
isClient(compatibility_pack_word_excel_powerpoint).
isClient(visual_basic).
isClient(ie).
isClient(excel).
```

Appendix B

OWL and Protege

B.1 Cyber Essential controls as OWL attributes

OWL ATTRIBUTE	ADJUSTED CVSS variable
ApplicationSandbox	**CollateralDamagePotential**: ApplicationSandbox(to all unknown apps) = 0.1, (selected apps only) = 0.2
ApplicationWhiteListing	**CollateralDamagePotential**: ApplicationWhitelisting(with approval process) = 0.3, (no approval process) = 0.35
BehindHostFirewall	**AccessVector**: BehindHostFirewall (OOB admin or MFA) = 0.395, (in band admin) = 0.52
BehindNetFirewall	**AccessVector:** BehindNetFirewall (OOB admin or MFA) = 0.395, (in band admin) = 0.395
CERTauthentication	**Authentication:** 3 levels: 0.45, 0.56, 0.704 – single: 0.56
DeviceHardeningPolicy	**AccessComplexity:** On build, and subject to ongoing audit = 0.35, not subject to audit = 0.48
DisasterRecoveryStrategy	**AvailImpact:** 3 levels: 0, 0.275, 0.660 – none:0.0
End2EndPipeLineEncryption	**ConfImpact:** 3 levels: 0, 0.275, 0.660 – none:0.0
IntrusionDetectionDeployed	**IntegImpact:** 3 levels: 0, 0.275, 0.660 – partial:0.275
IPSandDoSMitigation	**IntegImpact:** 3 levels: 0, 0.275, 0.660 – none:0.0
LDAPauthentication	**Authentication:** 3 levels: 0.45, 0.56, 0.704 – multiple:0.56
MultiFactorAuthentication	**Authentication:** 3 levels: 0.45, 0.56, 0.704 – multiple:0.45
NoAuthentication	**Authentication:** Authentication=:0.45
NoFirewall	**AccessVector:** 3 levels: 0.395, 0.646, 1.0 – network:1.0
NoHardeningPolicy	**AccessComplexity:** 3 levels: 0.35, 0.61, 0.71 – low:0.71
NoPatchAvailable	**RemediationLevel:** 5 levels: 0.87, 0.90, 0.95, 1.00, 1.00) – 1.0
OfficialPatchAvail	**RemediationLevel:** 5 levels: 0.87, 0.90, 0.95, 1.00, 1.00) – 0.87
PartialHardeningPolicy	**AccessComplexity:** 3 levels: 0.35, 0.61, 0.71 – medium - 0.61
PartialPipelineEncryption	**ConfImpact:** 3 levels: 0.0, 0.275, 0.660 – partial - 0.275
PasswdPolicyAutoEnforce	**Authentication:** 3 levels: 0.45, 0.56, 0.704 – single- 0.56
TempFixAvail	**RemediationLevel:** 5 levels: 0.87, 0.90, 0.95, 1.00, 1.00) – 0.9
DisasterRecoveryPartial	**AvailImpact:** 3 levels: 0, 0.275, 0.660 – impact partial- 0.275

B.2 Security Policies for Evaluation

Key

:Policy description

:OWL attribute describing CVSS metric value.

POLICY 1

Uses extensive firewall control at the perimeter and Citrix over IPSEC remote access.

Access is behind a network firewall but no host firewalls are used(BehindNetworkFirewall)

Citrix is used for external access to the Win2000 server(End2EndPipeLineEncryption)

RSA two factor authentication is used on Win2000 and VPN servers(MultiFactorAuthentication)

A Patching strategy is not to be used at present(NoPatchAvailable)

A full disaster recovery strategy is in place using resilient architecture(DisasterRecoveryStrategy)

No IDS or IPS is used on the network at this time.

Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)

No application whitelisting or sandbox is used.

POLICY 2

This security approach uses a Citrix gateway to control user access using LDAP authentication. However the internal connectivity to the windows server is unencrypted. Server access is IPSEC VPN controlled and uses Radius authentication.

Access is behind a network firewall but host firewalls are not used(BehindNetworkFirewall)

Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)

LDAP authentication is used on the Win2000 server and Radius at VPN(LDAPAuthentication)

A Patching strategy is not to be used at present(NoPatchAvailable)

There is a partial disaster recovery strategy in place(DisasterRecoveryStrategyPartial)

No IDS or IPS is used on the network at this time.

Device hardening policies are partially employed on the server builds(PartialHardeningPolicyApplies)

No application whitelisting or sandbox is used.

POLICY 3

This approach uses a more porous firewall perimeter with host firewalls deployed extensively. The internal Citrix connectivity to the windows server is unencrypted. A patching policy is not in place but device hardening is fully implemented and controlled. Partial disaster recovery measures are used.

Access is behind a network firewall with host firewalls also used(BehindHostFirewall)
Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)
LDAP authentication is used on the Win2000 server and Radius at VPN(LDAPAuthentication)
A Patching strategy is not to be used at present(NoPatchAvailable)
There is a partial disaster recovery strategy in place(DisasterRecoveryStrategyPartial)
No IDS or IPS is used on the network at this time.
Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)
No application whitelisting or sandbox is used.

POLICY 4

This security approach uses a granular network firewall perimeter, host firewalls are not deployed. The internal Citrix connectivity to the windows server is unencrypted. A full patching policy is in place and device hardening fully implemented and controlled. Partial disaster recovery measures are used. All users are issued with two factor authentication tokens.
Access is behind a network firewall but host firewalls are not use(BehindNetworkFirewall)
Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)
LDAP authentication is used on the Win2000 server and Radius at VPN(LDAPAuthentication)
A Patching strategy is to be used(OfficialPatchAvailable)
There is a partial disaster recovery strategy in place(DisasterRecoveryStrategyPartial)
No IDS or IPS is used on the network at this time.
Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)
No application whitelisting or sandbox is used.

POLICY 5

This security approach uses a granular network firewall perimeter, host firewalls are not deployed. The internal Citrix connectivity to the windows server is unencrypted. A full patching policy is in place and device hardening fully implemented and controlled. Partial disaster recovery measures are used. All users are issued with two factor authentication tokens. A full IPS infrastructure is also in play.
Access is behind a network firewall but host firewalls are not use(BehindNetworkFirewall)
Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)
RSA tokens are used on the Win2000 server and Radius at VPN(MultiFactorAuthentication)
A Patching strategy is to be used(OfficialPatchAvailable)
There is a partial disaster recovery strategy in place(DisasterRecoveryStrategyPartial)

A full IPS and DoS infrastructure is deployed on the network(IPSandDoSMitigation)
Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)
No application whitelisting or sandbox is used.

POLICY 6

This security approach uses a granular network firewall perimeter, host firewalls are not deployed. The internal Citrix connectivity to the windows server is unencrypted. A full patching policy is not in place and some servers are hardened but some have been built in house and not subject to a managed hardening policy. Password authentication is used in places on some servers, even for admin rights. No disaster recovery measures are used but Application whitelisting is used extensively(time consuming to deploy) and a limited IDS(not IPS) is deployed.

Access is behind a network firewall but host firewalls are not use(BehindNetworkFirewall)
Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)
Password authentication exists in places. Some attempt is made to control(NoAuthentication)
A robust Patching strategy is not in use(TempFixAvailable)
There is no disaster recovery strategy in place
IDS but not IPS is used on the network in some places(IntrusionDetectionDeployed)
Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)
Application whitelisting is used.(ApplicationWhiteListingApplies)

POLICY 7

This security approach uses a granular network firewall perimeter, host firewalls are not deployed. The internal Citrix connectivity to the windows server is unencrypted. A full patching policy is in place and some servers are hardened but some have been built in house and not subject to a managed hardening policy. Password authentication is used in places on some servers, even for admin rights. No disaster recovery measures are used but Application sandboxing is used extensively(hybrid cloud service) and a limited IDS(not IPS) is deployed.

Access is behind a network firewall but host firewalls are not use(BehindNetworkFirewall)
Citrix used for external access but unencrypted to Win2000 server(PartialPipeLineEncryption)
Password authentication exists in places. Some attempt is made to control(NoAuthentication)
A robust Patching strategy is in use(OfficialPatchAvailable)
There is no disaster recovery strategy in place

IDS but not IPS is used on the network in some places(IntrusionDetectionDeployed)
Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)
Application sandboxing is used.(ApplicationSandboxApplies)

POLICY 8

This security approach uses a more porous firewall perimeter with host firewalls deployed extensively. The internal Citrix connectivity to the windows server is also fully encrypted. A patching policy is not in place but device hardening is fully implemented and controlled. Partial disaster recovery measures are used. Full 2 factor authentication is used throughout the organisation.
Access is behind a network firewall but host firewalls are also used(BehindHostFirewall)
Citrix used for external access and encrypted to Win2000 server(End2EndPipeLineEncryption)
Full AD authentication is in place. (LDAPAuthentication)
A robust Patching strategy is not in use(NoPatchAvailable)
There is a partial disaster recovery strategy (DisasterrecoveryStrategyPartial)
No IDS or IPS is used on the network
Device hardening is employed on all server builds(DeviceHardeningPolicyApplies)
No Application whitelisting or sandboxing is used.

Appendix C

Tools Summary

This appendix outlines the methods and tools used to construct and use the risk framework.

Attack graphs are constructed using the ***MulVAL*** tool. Bayesian Networks are constructed and visualised using the ***GeNie*** Tool (GeNie Academic version 2.5) from BayesFusion (https://www.bayesfusion.com) and integrated with the risk framework using its ***SMILE*** API. (https://support.bayesfusion.com/docs/Wrappers). ***Python version 2.7*** is the language of choice for all coding. OWL ontologies are created using the ***Protege Desktop ontology editor*** from Stanford University (https://protegewiki.stanford.edu/wiki/) along with the ***Owlready2*** python module. A useful text for OWL 2.0 ontology programming is [17]. Visualisation of the game approaches to decision making is performed using the ***Gambit*** tool from Sourceforge (https://gambit.sourceforge.net). UML modelling of agile design patterns uses ***Eclipse Papyrus*** (https://www.eclipse.org/papyrus/)

Appendix D

Attack Graph from Chapter4

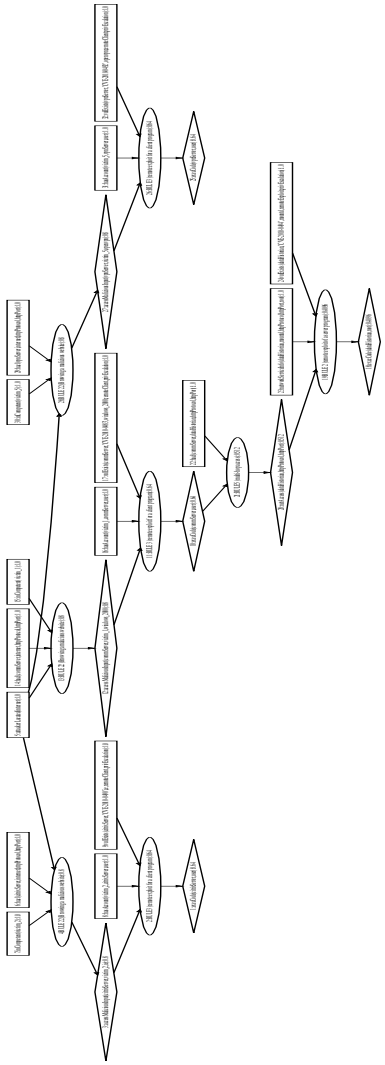


Figure D.1: Full Attack graph from Chp4